

**NIST Special Publication
NIST SP 800-124r2**

Guidelines for Managing the Security of Mobile Devices in the Enterprise

Gema Howell
Joshua M. Franklin
Vincent Sritapan
Murugiah Souppaya
Karen Scarfone

This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-124r2>

**NIST Special Publication
NIST SP 800-124r2**

Guidelines for Managing the Security of Mobile Devices in the Enterprise

Gema Howell
Joshua M Franklin*
*Applied Cybersecurity Division
Information Technology Laboratory*

Vincent Sritapan
*Cybersecurity and Infrastructure
Security Agency
Department of Homeland Security*

Murugiah Souppaya
*Computer Security Division
Information Technology Laboratory*

Karen Scarfone
Scarfone Cybersecurity

**Former NIST employee; all work for this
publication was done while at NIST.*

This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-124r2>

May 2023



U.S. Department of Commerce
Gina M. Raimondo, Secretary

National Institute of Standards and Technology
Laurie E. Locascio, NIST Director and Under Secretary of Commerce for Standards and Technology

Certain commercial equipment, instruments, software, or materials, commercial or non-commercial, are identified in this paper in order to specify the experimental procedure adequately. Such identification does not imply recommendation or endorsement of any product or service by NIST, nor does it imply that the materials or equipment identified are necessarily the best available for the purpose.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST.

Organizations are encouraged to review all draft publications during public comment periods and provide feedback to NIST. Many NIST cybersecurity publications, other than the ones noted above, are available at <https://csrc.nist.gov/publications>.

Authority

This publication has been developed by NIST in accordance with its statutory responsibilities under the Federal Information Security Modernization Act (FISMA) of 2014, 44 U.S.C. § 3551 et seq., Public Law (P.L.) 113-283. NIST is responsible for developing information security standards and guidelines, including minimum requirements for federal information systems, but such standards and guidelines shall not apply to national security systems without the express approval of appropriate federal officials exercising policy authority over such systems. This guideline is consistent with the requirements of the Office of Management and Budget (OMB) Circular A-130.

Nothing in this publication should be taken to contradict the standards and guidelines made mandatory and binding on federal agencies by the Secretary of Commerce under statutory authority. Nor should these guidelines be interpreted as altering or superseding the existing authorities of the Secretary of Commerce, Director of the OMB, or any other federal official. This publication may be used by nongovernmental organizations on a voluntary basis and is not subject to copyright in the United States. Attribution would, however, be appreciated by NIST.

NIST Technical Series Policies

[Copyright, Use, and Licensing Statements](#)
[NIST Technical Series Publication Identifier Syntax](#)

Publication History

Approved by the NIST Editorial Review Board on 2023-05-05
Supersedes NIST SP 800-124 Revision 1 (June 2013) <https://doi.org/10.6028/NIST.SP.800-124r1>

How to Cite this NIST Technical Series Publication:

Howell G, Franklin JM, Sritapan V, Souppaya MP, Scarfone KA (2023) Guidelines for Managing the Security of Mobile Devices in the Enterprise . (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800-124r2. <https://doi.org/10.6028/NIST.SP.800-124r2>

Author ORCID iDs

Gema Howell: 0000-0002-0428-5045
Murugiah Souppaya: 0000-0002-8055-8527
Karen Scarfone: 0000-0001-6334-9486

NIST SP 800-124r2
May 2023

Guidelines for Managing the Security
of Mobile Devices in the Enterprise

Contact Information

800-124comments@nist.gov

National Institute of Standards and Technology
Attn: Computer Security Division, Information Technology Laboratory
100 Bureau Drive (Mail Stop 2000) Gaithersburg, MD 20899-2000

All comments are subject to release under the Freedom of Information Act (FOIA).

Abstract

Mobile devices were initially personal consumer communication devices, but they are now permanent fixtures in enterprises and are used to access modern networks and systems to process sensitive data. This publication assists organizations in managing and securing these devices by describing available technologies and strategies. Security concerns inherent to the usage of mobile devices are explored alongside mitigations and countermeasures. Recommendations are provided for the deployment, use, and disposal of devices throughout the mobile-device life cycle. The scope of this publication includes mobile devices, centralized device management, and endpoint protection technologies, as well as both organization-provided and personally owned deployment scenarios.

Keywords

enterprise mobility management (EMM); mobile; mobile application vetting (MAV); mobile device management (MDM); mobile security; mobile threat defense (MTD); tablets.

Reports on Computer Systems Technology

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. The Special Publication 800-series reports on ITL's research, guidelines, and outreach efforts in information system security, and its collaborative activities with industry, government, and academic organizations.

Trademark Information

All registered trademarks or other trademarks belong to their respective organizations.

Patent Disclosure Notice

NOTICE: ITL has requested that holders of patent claims whose use may be required for compliance with the guidance or requirements of this publication disclose such patent claims to ITL. However, holders of patents are not obligated to respond to ITL calls for patents and ITL has not undertaken a patent search in order to identify which, if any, patents may apply to this publication.

As of the date of publication and following call(s) for the identification of patent claims whose use may be required for compliance with the guidance or requirements of this publication, no such patent claims have been identified to ITL.

No representation is made or implied by ITL that licenses are not required to avoid patent infringement in the use of this publication.

Table of Contents

Executive Summary	1
1. Introduction	2
1.1. Purpose	3
1.2. Scope	3
1.3. Audience	3
1.4. Document Structure.....	3
1.5. Document Conventions	4
2. Overview of Mobile Devices	4
2.1. Mobile Device Definition	4
2.2. Mobile Device Characteristics.....	5
2.3. Mobile Device Components.....	6
2.4. Mobile Communication Mechanisms and Other Common Mobile Components	7
3. Threats to the Mobile Enterprise	9
3.1. Threats to Enterprise Use of Mobile Devices	9
3.1.1. Exploitation of Underlying Vulnerabilities in Devices	9
3.1.2. Device Loss and Theft	10
3.1.3. Exploitation of Supply Chain Vulnerabilities	10
3.1.4. Accessing Enterprise Resources Via a Misconfigured Device.....	10
3.1.5. Credential Theft Via Phishing.....	11
3.1.6. Installation of Unauthorized Certificates	11
3.1.7. Use of Untrusted Mobile Devices	11
3.1.8. Wireless Eavesdropping	11
3.1.9. Mobile Malware.....	12
3.1.10. Information Loss Due to Insecure Lock Screen Configuration.....	12
3.1.11. User Privacy Violations	12
3.1.12. Data Loss via Synchronization.....	13
3.1.13. Shadow IT Usage	13
3.2. Threats to Device Management Systems	14
3.2.1. Exploitation of Vulnerabilities within the Underlying EMM Platform	14
3.2.2. EMM Administrator Credential Theft	14
3.2.3. Insider Threat	15
3.2.4. Installation of Malicious Developer and EMM Profiles	15
4. Overview of Mobile Security Technologies	15
4.1. Device-Side Management and Security Technologies	16
4.1.1. Hardware-Backed Processing and Storage	16

4.1.2.	Data Isolation Mechanisms	16
4.1.3.	Platform Management APIs	17
4.1.4.	VPN Support.....	17
4.1.5.	Authentication Mechanisms	17
4.2.	Enterprise Mobile Security Technologies	18
4.2.1.	Enterprise Mobility Management.....	18
4.2.2.	Mobile Application Management	20
4.2.3.	Mobile Threat Defense.....	21
4.2.4.	Mobile App Vetting.....	22
4.2.5.	Virtual Mobile Infrastructure	22
4.2.6.	Application Wrapping	23
4.2.7.	Secure Containers	23
4.3.	Recommended Mitigations and Countermeasures	23
4.3.1.	EMM Technologies	25
4.3.2.	Cybersecurity Recommended Practices	26
4.3.3.	Remote/Secure Wipe.....	26
4.3.4.	Security-Focused Device Selection.....	26
4.3.5.	Use Secure Connections to Resources	27
4.3.6.	Rapid Adoption of Software Updates	28
4.3.7.	OS and Application Isolation	29
4.3.8.	Mobile Application Vetting.....	30
4.3.9.	Mobile Threat Defense.....	30
4.3.10.	User Education	31
4.3.11.	Mobile Device Security Policies	31
4.3.12.	Notification and Revocation of Enterprise Access	32
4.3.13.	Strong Authentication	32
5.	Enterprise Mobile Device Deployment Life Cycle	33
5.1.	Identify Mobile Requirements	34
5.1.1.	Explore Mobile Use Cases.....	34
5.1.2.	Survey Current Inventory	34
5.1.3.	Choose Deployment Model.....	35
5.1.4.	Select Devices	37
5.1.5.	Determine EMM Capabilities.....	37
5.2.	Perform Risk Assessment.....	38
5.3.	Implement Enterprise Mobility Strategy.....	38
5.3.1.	Select and Install Mobile Technology	38

5.3.2.	Integration of EMM into the Enterprise Service Infrastructure	41
5.3.3.	Set Policy, Device Configuration, and Provision.....	42
5.3.4.	Define EMM Policy	42
5.3.5.	Verification Testing	44
5.3.6.	Deployment Testing.....	44
5.4.	Operate and Maintain	45
5.4.1.	Auditing	45
5.4.2.	Device Usage	46
5.5.	Dispose of and/or Reuse Device	46
References		47
Appendix A. Change Log		51

List of Tables

Table 1. Threat Mitigations and Countermeasures	24
--	----

List of Figures

Fig. 1. Enterprise Mobile Device Lifecycle	2
Fig. 2. Mobile Device Components	7
Fig. 3. Other Common Mobile Components.....	8
Fig. 4. Enterprise Mobile Device Deployment Life Cycle.....	33
Fig. 5. Example On-Premises Mobile Architecture	40
Fig. 6. Example Cloud-Based Mobile Architecture	41

Acknowledgments

The authors wish to thank the Federal CIO Council's Mobile Technology Tiger Team and the Advanced Technology Academic Research Center (ATARC) Mobile Working Groups. The authors especially appreciate the contributions of Wayne Jansen, who co-authored the original version of this publication. The authors also thank all of the individuals and organizations that provided comments on the publication, including Andrew Regenscheid and Nelson Hastings of NIST, Jeffrey A. Myers of the Department of Homeland Security (DHS), Deborah Shands and Kareem Eldefrawy of SRI International, and Michael Peck and Terri Phillips of MITRE.

Executive Summary

Modern mobile devices, which are essentially general-purpose computing platforms capable of performing tasks far beyond the voice and text capabilities of legacy mobile devices, are widespread within modern enterprise networks. Mobility has transformed how enterprises deliver information technology (IT) services and accomplish their missions. Targeted toward consumers for on-demand personal access to communications, information, and services, these devices are not configured by default for business use. As mobile devices perform everyday enterprise tasks, they regularly process, modify, and store sensitive data. While organizations understand that using mobile devices and mobile applications for anytime, anywhere access can increase employee productivity and enhance decision making and situational awareness, these devices bring unique threats to the enterprise.

As consumers and enterprise organizations have increased their adoption and use of mobile technologies, the mobile threat landscape has also shifted. This includes an increase in mobile malware and vulnerabilities that span the device (e.g., operating system, firmware, the baseband processor used to access cellular networks), mobile apps, networks, and management infrastructure. The diversity and complexity of the mobile ecosystem and the rapid pace of change challenge the selection, integration, and management of mobile technologies in enterprise IT environments. To reduce the risk to sensitive data and systems, enterprises need to institute appropriate policies and infrastructure to manage and secure mobile devices, applications, content, and access.

Mobile devices often need additional protections as a result of their portability, small size, and common use outside of an organization's network, which generally places them at higher exposure to threats than other endpoint devices. Laptops are excluded from the scope of this publication. Although some laptop/desktop management technologies are converging with mobile device management technologies, the security capabilities currently available for laptops are different than those available for smartphones, tablets, and other mobile device types. Furthermore, mobile devices contain features that are not generally available in laptops (e.g., multiple wireless network interfaces, Global Positioning System, numerous sensors, built-in mobile apps). Devices with minimal computing capability, such as the most basic cell phones and general Internet of Things (IoT) devices, are also out of scope because they typically do not have a full-fledged operating system (OS), and their functionality and available security options are limited.

Organizations can use the Enterprise Mobile Device Deployment Life Cycle (**Fig. 1**) to improve the security of their mobile devices.

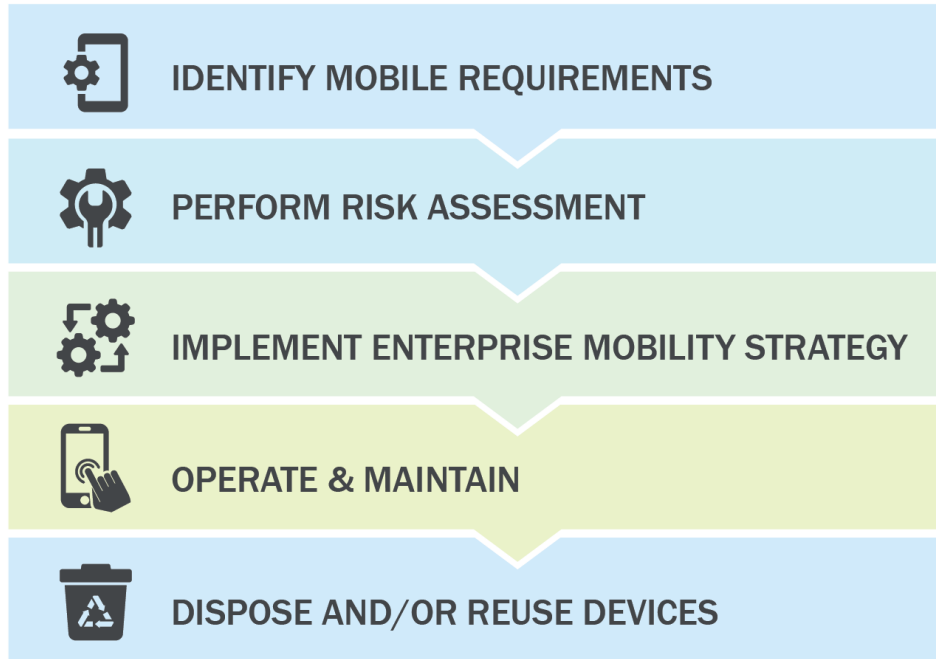


Fig. 1. Enterprise Mobile Device Lifecycle

Organizations can implement the following to build and maintain the security of their mobile device deployment:

- Conduct a threat analysis for mobile devices and any information systems accessed from mobile devices.
- Employ enterprise mobility management, mobile threat defense, mobile application vetting, and other applicable enterprise mobile security technologies.
- Implement and test a pilot of a mobile device solution before putting the solution into production.
- Fully secure each organization-issued mobile device before allowing a user to access the organization's systems or information.
- Keep mobile operating systems and apps updated.
- Regularly monitor and maintain mobile device security.

1. Introduction

Mobile devices are no longer new to the workplace. Modern mobile devices are essentially general-purpose computing platforms capable of performing tasks far beyond the voice and text capabilities of legacy mobile devices. Smartphones and tablets process enterprise information and are regularly included in the design phase of modern network architectures. Multiple mature mobile operating systems (OSs) are available in the marketplace and have a variety of functionality to secure these devices in the workplace. New mobile technologies for the enterprise are still being introduced. Full equity does not yet exist when comparing the

management technology available for traditional desktop environments and those afforded to security professionals to secure their mobile devices, although they are constantly evolving and maturing.

1.1. Purpose

The purpose of this publication is to assist organizations with managing and securing mobile devices. This publication provides recommendations for selecting, implementing, and managing devices throughout their life cycle via centralized management technologies. Additionally, security concerns inherent to mobile devices are explored alongside mitigation strategies. This approach includes protecting enterprise information such as email, contacts, calendar, and web browsing, which are some of the most commonly used applications in the workplace. This can be expanded to include the protection of enterprise-developed and third-party applications and the sensitive enterprise data they store and process. Recommendations are also provided for the deployment, use, and disposal of devices throughout the mobile device life cycle. This publication can be used to inform risk assessments, build threat models, enumerate the attack surface of the mobile infrastructure, and identify mitigations for mobile deployments.

1.2. Scope

This publication is scoped to the management of mobile devices in the enterprise. Mobile devices primarily include mobile phones and tablets but also include other devices that run a modern mobile OS, such as Chromebooks which can run Android apps. Laptops are specifically excluded from the scope of this publication as the security controls available today for laptops are quite different than those available for mobile phones, tablets, and other mobile device types. Mobile devices with minimal computing capability are excluded, including feature phones, wearables, and other devices included under the Internet of Things (IoT) umbrella. This document does not discuss the mechanisms needed to evaluate the security of mobile applications [\[2\]](#) or to securely deploy and maintain a cellular network [\[3\]](#). Unique feature sets available in specialized areas (e.g., construction, public safety, medical) are not analyzed or discussed.

1.3. Audience

This document is intended for information security officers, information security engineers, security analysts, system administrators, chief information officers (CIOs), and chief information security officers (CISOs). Other organization personnel may find this document helpful, such as security managers, engineers, analysts, administrators, and others who are responsible for planning, implementing, and maintaining the security of mobile devices. This document assumes that readers have a basic understanding of mobile device technologies, networking, and enterprise security principles.

1.4. Document Structure

The remainder of this document is organized into the following sections and appendices:

- Section 2 provides an overview of mobile devices that focuses on what makes them different from other computing devices, particularly in terms of security.
- Section 3 discusses threats to an enterprise's use of mobile devices.
- Section 4 presents an overview of mobile security technologies and discusses mitigations and countermeasures to the threats listed in Section 3.
- Section 5 discusses security throughout the mobile device life cycle. Examples of topics addressed in this section include mobile device security policy creation, design and implementation considerations, and operational processes that are particularly helpful for security.
- The References section contains a complete list of references cited in this document.
- Appendix A defines selected acronyms and abbreviations used in this publication.

1.5. Document Conventions

The following conventions are used throughout this document:

- “app” is used in place of mobile application.
- WiFi is written without a hyphen

2. Overview of Mobile Devices

This section defines what a modern mobile device is, outlines the characteristics of mobile devices, and discusses their underlying architecture. Understanding the full composition of a mobile device is useful in defining the threats facing these information systems. This section also provides an overview of built-in security capabilities, such as isolation, communication, and authentication mechanisms.

2.1. Mobile Device Definition

Mobile devices are essentially general-purpose computing platforms. They are not restricted to performing one operation and can instead be used in many different domains, including medical, industrial, and entertainment. NIST SP 800-53, Rev. 5 [\[1\]](#) defines a mobile device as:

A portable computing device that has a small form factor such that it can easily be carried by a single individual; is designed to operate without a physical connection (e.g., wirelessly transmit or receive information); possesses local, non-removable data storage; and is powered on for extended periods of time with a self-contained power source. Mobile devices may also include voice communication capabilities, on-board sensors that allow the device to capture (e.g., photograph, video, record, or determine location) information, and/or built-in features for synchronizing local data with remote locations.

This definition emphasizes portability, wireless communication, local storage, and long battery life – all of which exist in modern smartphones and tablets. It is common for these systems to have an always-on cellular connection, but this feature is not shared by all mobile devices. In fact, many tablets lack a cellular modem yet still run a mobile OS. It is also not a requirement that mobile devices run applications or *apps*, although this capability is commonplace. Applications are used to expand a mobile device's basic functionality.

2.2. Mobile Device Characteristics

Commercially available mobile devices lack a unified set of features. Each feature and characteristic has the potential to introduce new threats to security and privacy, so it is important to establish a baseline understanding of the set of characteristics that are common to mobile devices. The following list explores the baseline characteristics of a mobile device for the purposes of this publication:

- Operating system: A mobile device comes with a rich OS that can be used in a variety of ways. This is the primary distinction between mobile devices and IoT devices, which typically do not have a full-fledged OS and have limited functionality.
- Small form factor: The size of a mobile device allows for easy portability.
- Self-contained power source: Mobile devices traditionally house a self-contained power source. Some mobile devices are capable of swapping out their battery power source for another.
- Physical port: A physical connection can be used to sync/transfer data or to charge the device. Some phones have wireless charging capabilities.
- Wireless network interface: Mobile devices have at least one wireless network interface for data communications, often offering connectivity to the internet or other data networks.
- Data storage: Mobile devices contain local, built-in, and non-removable data storage.
- Apps: A mobile device ships with native apps to handle common operations. Beyond native apps, most mobile devices also support third-party apps, which usually add functionality and significantly expand a device's utility.
- Management capability: Mobile devices include a consistent way to manage the device via application programming interfaces (APIs) or proprietary mechanisms.

The following details other common characteristics of mobile devices. These features do not define the scope of devices included in the publication but rather indicate features that are particularly important in terms of security. This is not intended to be an exhaustive list.

- Network services: A mobile device may come with additional networking capabilities, such as Bluetooth, WiFi, near-field communications (NFC), and cellular data and voice (e.g., 4G LTE or 5G).
- Camera: Mobile devices may use one or more digital cameras that are capable of capturing photos and video recordings. Cameras also accept biometric input to unlock a

device or can interpret non-human readable data formats (e.g., Quick Response [QR] codes).

- **Sensors:** Sensors within a mobile device capture data to perform an operation, such as authentication or measurement. Examples include a gyroscope, accelerometer, magnetometer, biometric reader, pedometer, infrared, barometer, photometer, and thermometer.
- **Speaker and/or microphone:** A mobile device usually has a speaker that provides an audio output ability and/or a microphone that provides audio input ability.
- **Removable media:** Removable media allows for additional data and memory storage on a mobile device, normally provided through a secure digital (SD) card. Removable media also serves as a way to transport data from one mobile device to another device.
- **Data synchronization/backup services:** Mobile devices have built-in features for synchronizing local data with a different storage location (e.g., desktop or laptop computer, organization servers, telecommunications provider servers, other third-party servers, etc.).
- **Hardware-backed security module:** A mobile device uses a hardware module or some portion of a hardware chip to perform cryptographic functions and store sensitive cryptographic keys and secrets.

2.3. Mobile Device Components

Multiple organizations work in concert to provide the hardware, firmware, software, and other technology that make up a mobile device. For smartphones and tablets with cellular capabilities, a separation exists between the hardware and firmware used to access cellular networks and the hardware and firmware used to operate the general-purpose mobile OS. Users and administrators generally interact with the general-purpose mobile OS that utilizes the *application processor*. The hardware and firmware used to access the cellular network, often referred to as the *telephony subsystem*, typically runs a completely separate real-time operating system (RTOS). This telephony subsystem utilizes a completely separate system on a chip (SoC) called the *baseband processor*. This often means that a cellular-enabled smartphone is concurrently running multiple OSs.

Other features of the telephony subsystem include the universal integrated circuit card (UICC), international mobile equipment identifier (IMEI), and the international mobile subscriber identity (IMSI), also known as a subscription permanent identifier (SUPI). The UICC, also known as the subscriber identity module (SIM) card, stores cryptographic information and personal data and is used to enable access to the cellular network. The IMEI is an identifier specific to a mobile device and is used to uniquely identify a device to the cellular network. The IMSI is used to uniquely identify a subscriber or user on the network. More information on these features can be found in NIST SP 800-187, *Guide to LTE Security* [3].

A set of lower-level systems exists in the form of firmware to initialize the device and load the mobile OS into memory, which includes the bootloader. This initialization firmware may also verify other device initialization code, including device drivers. All of this activity occurs before a user can interact with the device. If the initialization code is modified or tampered with, the

device may not properly boot or may function in a completely unacceptable manner (e.g., a Trojan horse). Many modern mobile devices contain an isolated execution environment that is used specifically for security-critical functions [6]. For example, these environments may be used for sensitive cryptographic operations (e.g., to verify integrity) or to support digital rights management (DRM). These environments typically have access to some amount of secure storage that is only accessible within that environment.

The mobile OS enables a rich set of functionalities by supporting the use of mobile apps written by third-party developers. All mobile apps are sandboxed (or securely separated) in some manner to prevent unexpected and unwanted interactions between the system, its apps, and those apps' respective data. This includes preventing user data stored by different apps from interacting with each other. Mobile apps may be written in a native language running close to the hardware, in interpreted languages, or in high-level web languages. The degree of functionality of mobile applications is highly dependent on the APIs exposed by the mobile OS and the frameworks used by the developer. Functionality is also dependent on the level of permissions granted to allow the mobile app to leverage mobile device features, such as the camera or microphone.

This section has described the various technologies that work together to make a mobile device function. **Fig. 2** illustrates a visual model of the previously discussed layers of a mobile device.

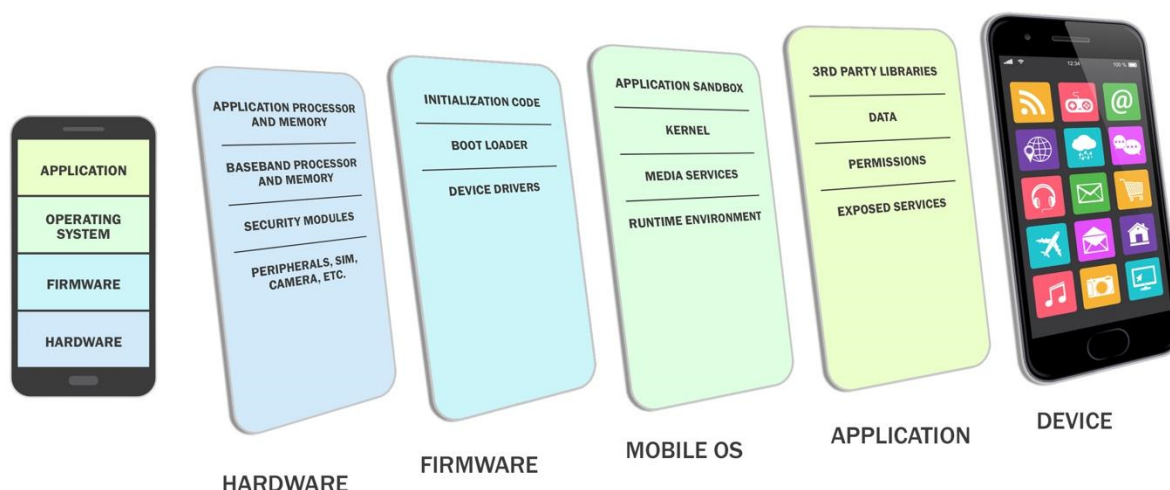


Fig. 2. Mobile Device Components

2.4. Mobile Communication Mechanisms and Other Common Mobile Components

Mobile devices support a variety of wireless communication protocols, such as cellular, WiFi, Bluetooth, Global Positioning System (GPS), and NFC. Wired physical connections are also commonplace via a power and synchronization cable using Micro-USB, USB-C, and others. **Fig. 3** depicts some of the communication mechanisms offered and additional common components found in mobile devices.

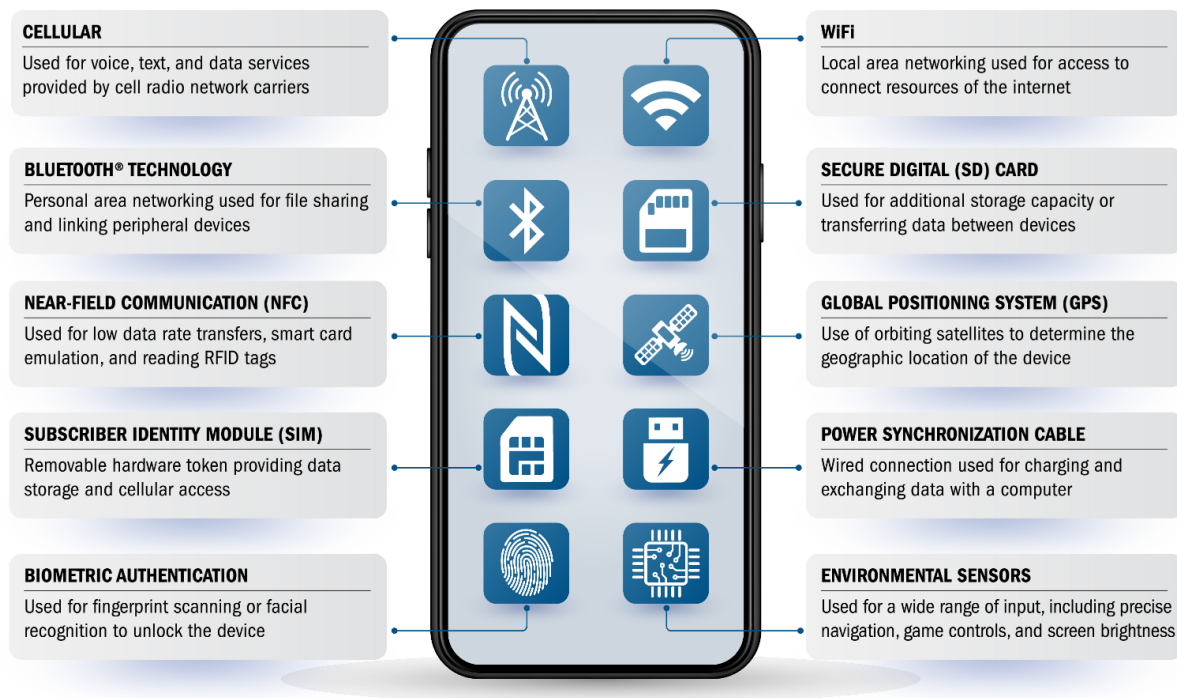


Fig. 3. Other Common Mobile Components

WiFi is a wireless local area network (WLAN) technology and is generally available on most mobile devices. WiFi devices often connect via a centralized wireless access point (AP) but can also work in a device-to-device ad hoc mode. Bluetooth is a short-range wireless communication technology primarily used to establish wireless personal area networks (WPANs). Bluetooth technology is common in consumer mobile devices and can be used to communicate with headsets, wearables, keyboards, mice, and other IoT devices. Another form of short-range wireless communication is NFC, which is typically optimized for distances of less than 4 inches but may be vulnerable at greater distances. NFC is based on the radio frequency identification (RFID) set of standards. Mobile payment technology commonly relies on NFC, which has led to a large increase of use in recent years.

A global navigational satellite system (GNSS) provides worldwide, geospatial positioning via GPS. GPS uses line-of-sight communication with a satellite constellation in orbit to help a handset determine its location. These systems run independently of cellular networks. The U.S. Federal Government operates a GPS constellation, although mobile devices may use other constellations (e.g., Global Navigation Satellite System [GLONASS], Galileo). The U.S. Federal Communications Commission (FCC) mandates that cellular devices must have GPS built-in for public safety and emergency medical reasons. It should be noted that the GPS system is not the only way to identify a mobile device's location. Other techniques include cellular positioning, WiFi-assisted positioning, and geolocation of IP addresses.

3. Threats to the Mobile Enterprise

Mobile devices support a series of security objectives, but these can differ based on the organization. These mobile security objectives can be accomplished via a combination of security features built into, installed onto, or managed externally to mobile devices. Achieving an organization's security objectives often requires devices to be secured against a variety of threats. General security recommendations for any IT technology are provided in NIST SP 800-53, Security and Privacy Controls for Information Systems and Organizations [1]. Specific recommendations for securing mobile devices are presented in Section 4.3 of this publication and are intended to complement the controls specified in SP 800-53. See a summary of SP 800-53 controls tailored to mobile enterprise security that can be found in the following publications:

- NIST SP 1800-21, Mobile Device Security: Corporate-Owned Personally-Enabled (COPE) [49, p.147]
- NIST SP 1800-22, Mobile Device Security: Bring Your Own Device (BYOD) [50, p.101]

Before designing and deploying mobile device solutions, organizations should develop threat models for all facets of mobile device usage. Threat modeling involves identifying resources of interest and the feasible threats, vulnerabilities, and security controls related to these resources; quantifying the likelihood and impacts of successful attacks; and analyzing this information to determine where security controls should be improved or added. Threat modeling helps organizations identify security requirements and design the mobile device solution that incorporates the controls needed to meet the security requirements. The threat landscape evolves continually, and organizations can use threat intelligence to inform an updated risk assessment and security controls. The NIST Mobile Threat Catalogue [5] – a threat modeling process such as draft NIST SP 800-154, Guide to Data-Centric System Threat Modeling [47] – and the DHS Study on Mobile Device Security [23] can be used as a foundation for beginning threat modeling activities. The threats listed in the following sections are mapped to the corresponding threats from the NIST Mobile Threat Catalogue document.

3.1. Threats to Enterprise Use of Mobile Devices

The following threats are related to the general use of mobile devices.

3.1.1. Exploitation of Underlying Vulnerabilities in Devices

Software development is a complex discipline that creates the instruction set that powers mobile devices and apps. In the case of typical software, errors and vulnerabilities exist at an estimated frequency of ~25 errors per 1000 lines of code [32]. There are many definitions for vulnerabilities, but this report leverages the following definition [1]: “*Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by a threat source.*” Software vulnerabilities exist at all levels of the mobile device stack. Due to the nature of how mobile devices are developed and manufactured, multiple organizations will contribute software and firmware to the same device. The contributing organizations may or may not have robust software development practices and processes in place. A vulnerability in the code from any of these vendors could potentially

compromise the device [25]. An example exploitation is using vulnerabilities in the voice assistance or quick access features to bypass the lock screen and gain unauthorized access to a mobile device.

NIST Mobile Threat Catalogue Reference: STA-0 through STA-11

3.1.2. Device Loss and Theft

Mobile devices are used in a variety of locations outside of an organization's control, such as employee dwellings, coffee shops, hotels, and taxis. Some organizations have strict rules for mobile devices that state that they are only allowed to be used within an organization's perimeters. Yet many organizations have multiple sites, so mobile devices are transported from building to building. The portability of mobile devices makes them more likely to be lost or stolen than traditional desktop systems, and the sensitive data on these devices adds an increased risk of compromise to the organization.

NIST Mobile Threat Catalogue Reference: PHY-0

3.1.3. Exploitation of Supply Chain Vulnerabilities

Within the supply chain or the process of development and distribution of devices, there is the potential for the insertion of malicious hardware or malware. Mobile devices may contain malicious functionality and be vulnerable due to threats to the supply chain. These supply chain threats can include an adversary intercepting the hardware/firmware of mobile devices while the devices are in transit between a supplier and acquirer, or an adversary inserting malicious code into open-source code that is commonly used for mobile applications. The vulnerabilities that arise due to supply chain threats could be exploited and cause major issues when several devices within an organization are impacted. The vulnerabilities could include backdoors that provide an attacker with remote root access to the device.

NIST Mobile Threat Catalogue Reference: SPC-0 through SPC-21

3.1.4. Accessing Enterprise Resources Via a Misconfigured Device

Similar to most other information systems, mobile devices can be misconfigured. The mobile OS contains many security- and privacy-relevant configuration options, such as the use of a passcode, user tracking, VPNs, or other practices that allow for a secure connection to enterprise resources. Unfortunately, not all security- and privacy-relevant settings are located within the security options area of the mobile OS interface. Apps installed on the device can also be configured, sometimes within the administrative area of the device but also within the app itself. Relevant configurations include authentication to the app, tracking users, and the proper use of encryption. Connecting an improperly configured device to an enterprise resource, such as an enterprise file share, could expose information to entities monitoring the network or improperly accessing the device directly.

NIST Mobile Threat Catalogue Reference: STA-8

3.1.5. Credential Theft Via Phishing

Enterprise employees receive phone calls, emails, text messages, and app-related messages/notifications to their mobile devices on a daily basis. Sometimes, the authenticity of emails and texts can be difficult to determine. Attackers often attempt to steal or request an employee's user credentials through an email or text message. An employee may be tricked into believing the message is from a trusted source and provide their credentials or allow an attacker unauthorized access to their mobile device by clicking a hyperlink within the email or text message. These are examples of phishing on mobile devices.

NIST Mobile Threat Catalogue Reference: AUT-9

3.1.6. Installation of Unauthorized Certificates

Digital certificates are software cryptographic tokens used for authentication and signing software, among other things. These certificates can be distributed to devices through a variety of channels, including web browsers, physical connections (e.g., USB cable), and profiles applied through an EMM policy. Once a certificate is provided to a mobile device's certificate store, it can be used for authentication and making trust-based decisions about apps by showing warnings to users. The presence of a malicious certificate could trick a user's device into trusting a phishing site or installing a fake phishing or Trojan application, such as a banking app.

NIST Mobile Threat Catalogue Reference: ECO-23

3.1.7. Use of Untrusted Mobile Devices

Many mobile devices – particularly those that are personally owned – are not inherently trustworthy. For example, jailbreaking or rooting a device bypasses built-in restrictions on security, OS use, and other functions. Organizations should assume that all mobile devices are untrusted unless the organization has properly secured them and continuously monitors their security while the devices are used to access enterprise apps or data. Untrusted devices are the riskiest mobile devices, often have access to sensitive enterprise information, and are the easiest to compromise.

NIST Mobile Threat Catalogue Reference: STA-1

3.1.8. Wireless Eavesdropping

Because mobile devices primarily use non-enterprise networks for internet access, organizations typically have no control over the security of the external communications networks that the devices access and limited visibility into the wireless traffic that traverses these networks. Communications media may include wireless systems, such as Bluetooth, WiFi, and cellular networks. Bluetooth devices are often used to transmit audio information (e.g., voice traffic, music) as well as notifications and health information from wearable devices [\[31\]](#). WiFi and cellular can be used to transmit multiple types of traffic, including voice and data. All of these network protocols and media are susceptible to eavesdropping and man-in-the-middle (MitM) attacks that can intercept and modify communications between a device and an enterprise system [\[26\]](#).

NIST Mobile Threat Catalogue Reference: CEL-0, CEL-6, CEL-18, LPN-2, LPN-16

3.1.9. Mobile Malware

Mobile devices are designed to make it easy for users to find, acquire, and install third-party apps offered by app stores. Some users may sideload applications onto their device by allowing installation from untrusted or unknown sources. This accessibility poses significant security risks, especially for mobile device platforms and app stores that do not place security restrictions or other limitations on third-party app publishing. Organizations should base their mobile device security policy on the assumption that all unknown third-party apps downloaded by its employees to enterprise-accessible mobile devices are untrusted. Any application installed onto a mobile device can act as a portal for the developer to compromise the device and access sensitive enterprise information.

Mobile devices have many sensors, like microphones and cameras, to improve user functionality, such as making phone calls and taking advanced pictures. Most mobile devices have two cameras (front and back) and have at least one microphone for audio input. Mobile malware on a mobile device can use these sensors to unknowingly collect information about the user or the administrator. Microphones and cameras should only be exposed when in use and protected at all other times.

NIST Mobile Threat Catalogue Reference: APP-16, APP-26, APP-43, CEL-33, STA-15

3.1.10. Information Loss Due to Insecure Lock Screen Configuration

The lock screen is the first barrier that an unauthorized user must pass to gain access to information stored on a mobile device. The lock screen can be configured with an authentication factor to restrict access to the device. If poorly protected with a simple password, the lock screen may be breached through a brute-force attack. An unauthorized user who has compromised the authentication factor of a mobile device can access all sensitive information, modify the information, and pretend to be the device's owner to gain further access to enterprise data.

The lock screen can also be configured to display notifications related to missed calls or messages, app alerts, emails received, etc. Information shown on the lock screen, such as emails, may display sensitive enterprise information. These lock screen notifications may provide an unauthorized user with information without the need to unlock the mobile device.

NIST Mobile Threat Catalogue Reference: AUT-1

3.1.11. User Privacy Violations

The collection and monitoring of user or employee data can greatly undermine an individual's personal privacy. Many mobile apps collect and monitor user data such as location, contacts, browsing history, and general system information. This information is commonly used for marketing purposes to direct specific advertisements to the user. Mobile applications are not the only systems that collect user information, as most of the business systems (e.g., EMM, MTD) used for mobility may also have this capability, meaning that an employer may collect sensitive information about an employee. Under the Privacy Act of 1974, this type of data collection is

allowed as long as the business publicly notifies users of any data it has collected, including PII and other user information [37]. The collection of data without the user's consent hinders confidentiality and may be a privacy violation because the collected data may be used in an unwanted manner without the user's knowledge.

One common privacy violation is user location tracking. Location services are commonly used by applications such as social media, navigation and weather apps, and web browsers. In terms of organizational security and personal privacy, mobile devices with location services enabled are at increased risk of targeted attacks because it is easier for potential attackers to determine where the user and the mobile device are located and to correlate that information with other sources about who the user associates with and the kinds of activities they perform in a particular location. Although there can be positive cybersecurity impacts from accessing location services (e.g., enabling location-based policies and device configurations), this should require user consent and a thorough description of what type of personal information the enterprise can access.

NIST Mobile Threat Catalogue Reference: APP-24, APP-36, EMM-7

3.1.12. Data Loss via Synchronization

Mobile devices may interact with other systems to perform data exchange, synchronization, and storage. This can include both local and remote device syncing. Local synchronization generally involves connecting a mobile device to a desktop or laptop computer wirelessly or via a cable.

Remote system synchronization often involves automatic backups of data to a cloud-based storage system. When all of these components are under the organization's control, risk is generally acceptable, but one or more of these components are often external to the enterprise. Examples include connecting a personally owned mobile device to an organization-issued laptop, connecting an organization-issued mobile device to a personally owned laptop, connecting an organization-issued mobile device to a remote photo backup service, and connecting a mobile device to an untrusted charging station. In all of these scenarios, the organization's data is at risk of being stored in an unsecured location outside of the organization's control. In these scenarios, the transmission of malware from one device to another is also a possibility.

NIST Mobile Threat Catalogue Reference: EMM-9, STA-6

3.1.13. Shadow IT Usage

Organizations that implement a fully managed mobile device policy should be cognizant of the risks associated with shadow IT. The term "shadow IT" typically denotes staff members' work-related use of IT-related hardware, software, or cloud services without the knowledge of the IT organization. The canonical example of shadow IT is a department that performs mission-critical work using an independently purchased server running software that is not approved, managed, or even known by the larger IT organization. IT staff may not learn of the existence of this system until it fails or is breached, jeopardizing the critical mission.

Staff members often resort to the use of shadow IT systems when enterprise-provided systems and processes are seen as cumbersome or impeding work or when the enterprise fails to provide necessary systems. In the mobile systems environment, staff members may be motivated to use

personal devices to circumvent restrictive mobile device policies implemented by full enterprise management of enterprise-provided mobile devices. Staff members may send work-related emails or documents to their personal email accounts to better enable access during travel, use unapproved apps or cloud services to store enterprise data, or take pictures of whiteboard drawings with the camera on their personal devices. Staff members may also be motivated to use shadow IT when enterprise administration practices appear to invade their privacy (e.g., warnings that enterprise system administrators are permitted to monitor all communication from an enterprise-owned mobile phone). Another example involves tethering, such as using one mobile device to provide network access for another mobile device.¹

Shadow IT systems do not comply with organizational requirements for enterprise control or documentation and may or may not violate security or reliability policies. In a few cases, a benefit arising from shadow IT is that some of the technologies, software, or systems become part of the future enterprise due to their benefit in boosting productivity. Organizations should be aware of the potential threats from shadow IT for which there is no single, complete solution (e.g., EMM technologies do not completely address it) and should treat shadow IT seriously.

NIST Mobile Threat Catalogue Reference: N/A

3.2. Threats to Device Management Systems

The following threats are related to the use of EMM and other systems used to manage and secure mobile devices. More information describing EMMs can be found Section 4.2.1.

3.2.1. Exploitation of Vulnerabilities within the Underlying EMM Platform

EMM infrastructure and subsequent components run on top of commodity hardware, firmware, and software – all of which are susceptible to publicly known software and hardware flaws. Although systems are extensively customized, commodity hardware and well-known OSs should be identified and understood. These systems should be properly configured, to leverage the security configuration guides found in the NIST Checklists repository, and regularly patched to remediate known vulnerabilities, such as those listed in the National Vulnerability Database [\[38\]](#).

NIST Mobile Threat Catalogue Reference: EMM-1, EMM-2

3.2.2. EMM Administrator Credential Theft

Credential theft is a primary issue for employees, but the credentials of system administrators who work with the EMM console can also be compromised. If attackers can log into the EMM as an administrator, there could be a loss of sensitive information. EMMs store a variety of sensitive information about employees at all levels of an organization, such as email addresses, phone numbers, usernames, assigned resources, levels of access, and metadata from voice and text communication. Additionally, EMM administrator credentials allow an attacker to misconfigure and put mobile devices into an insecure state by modifying the policies enforced on the devices. Finally, an attacker may also be able to perform a denial-of-service (DoS) attack on

¹ Organizations should have policies regarding the use of tethering. If an organization permits tethering, it should ensure that the network connections involving tethering are strongly protected (e.g., communications encryption). If an organization prohibits tethering, it should configure mobile devices to prevent tethering.

an enterprise by erasing the enterprise's records from the EMM and removing enterprise access for all mobile devices.

NIST Mobile Threat Catalogue Reference: EMM-2

3.2.3. Insider Threat

An insider threat originates from an individual (e.g., a current or former employee) who uses authorized access to an organization's system to violate the organization's security policy. As an essential tool for secure mobile system administration, an EMM system may be a "double-edged sword." To wit, it may be used both as a mechanism for protecting an enterprise from insider threats (e.g., to implement practices focused on password and account management, access controls, system change controls, and app usage policies) and as an attack vector for a malicious insider. A malicious insider with access to an EMM system could weaken permissions to enable data leaks, enroll unauthorized devices or outsiders, or allowlist malicious apps, among other inappropriate actions. The use of EMM systems and other mobile device administration tools should be monitored carefully to detect possible malicious insider activities.

NIST Mobile Threat Catalogue Reference: EMM-2

3.2.4. Installation of Malicious Developer and EMM Profiles

The installation of EMM profiles enables an enterprise to control privileged operations provided by mobile OSs. There are multiple ways in which mobile device users can be enrolled into the EMM and profiles distributed to their mobile devices. One of the most common is installing an EMM application – sometimes referred to as an MDM agent – directly onto the mobile device. When this setup is completed, end users can enter information unique to their organization and authenticate to the EMM server. At this point, an EMM profile is presented to the user. This profile contains specific permissions and other resources approved by administrators.

EMM profiles can be conveyed to a user through a variety of avenues, such as email, text, and drive-by downloads. If a user accidentally accepts a malicious profile delivered via one of these methods, privileged access could be provided to an attacker. Using this access, an attacker can leverage all management APIs to access enterprise data on the device and possibly even information stored on backend infrastructure run by the organization.

NIST Mobile Threat Catalogue Reference: EMM-3, STA-7

4. Overview of Mobile Security Technologies

Mobile security technologies have evolved over the past decade to become full-featured security management suites. New capabilities and features are being added to increase the control that administrators have over their enterprise devices. Some of these capabilities are built into the device, whereas others are services provided by external systems that reside on more traditional web servers. Device-side security capabilities are introduced in Section 4.1 and are followed by a description of enterprise mobile security technologies in Section 4.2. Recommendations on how to mitigate the threats described in Section 3 through policy, user education, the use of security management technologies, and industry best practices are presented in Section 4.3.

4.1. Device-Side Management and Security Technologies

The following sections detail common on-device technologies used to enable management and enhance enterprise security. Note that not all mobile devices share the same functions and security capabilities.

4.1.1. Hardware-Backed Processing and Storage

Many mobile devices contain dedicated hardware components to protect cryptographic keys, passwords, digital certificates, biometric templates, and other sensitive information. These hardware components are also frequently used to support the encryption of user data on mobile devices. Some mobile devices offer dedicated components to perform sensitive operations, such as making security decisions (e.g., granting access to a privileged API) or performing cryptographic operations on data. On some platforms, secure data storage and sensitive operations are combined into a single SoC. iOS and Android devices both support hardware-backed processing and storage [\[21\]](#), [\[22\]](#).

Although these components may exist on devices, they may not be used by default. Apps must properly leverage the right APIs to fully utilize the security functions that are provided by the platform. On some platforms, APIs may not be exposed to all developers. On other platforms, small applications can be developed to run specifically within these restricted security environments.

Finally, devices may use other security modules or elements dedicated to specific tasks. These modules/elements are often meant to provide a secure implementation of a specific task. For example, some mobile payment solutions use a chip specifically designed to handle certain transactions and encrypt payment information stored within the chip.

4.1.2. Data Isolation Mechanisms

Mobile devices provide data isolation mechanisms to prevent unauthorized access to user and device data. Examples of data isolation mechanisms include encryption and application sandboxing. Isolating data using encryption separates the data based on authorized access. This mechanism means that only users who possess the appropriate cryptographic key can access the encrypted data on the device. Mobile devices encrypt user data, but data may be encrypted with a key that is managed by the OS and *not* the user, developer, or enterprise.

Sandboxing on a mobile device can be implemented in multiple ways. An app sandbox is implemented by the mobile OSs, which generally keeps apps from interacting with each other. Exceptions are made based on well-defined methods explicitly accepted by the user, such as asking a user if they grant permission for an application to do a task. Also, if apps are made by a common developer, they may be allowed to share information between one another because they are signed by the same developer key. Additional sandboxes may exist at or below the user level that provide an additional layer of data segmentation.

4.1.3. Platform Management APIs

The major mobile OS platforms offer a set of APIs and supporting protocols that can be used by third-party management tools [27][28]. Management APIs offer access to capabilities that are not offered to normal developers, such as controlling app behavior, configuring device and security settings, and querying sensitive device information. Access to these APIs may be restricted to a subset of particular developers vetted by the platform owners. Additionally, access to these APIs must be agreed to by either a device's end user or a member of an organization's IT staff. Note: Most device platforms only permit one MDM solution to control these APIs.

The management capabilities offered by the platform owners are also supplemented by external infrastructure, which is discussed further in Section 4.2.1. In some management situations, IT administrators are able to directly manage the devices, while in other settings, IT administrators send commands to the platform owner's infrastructure, which are subsequently relayed onward to the device. Both of these scenarios can be accommodated within the same management panel and be made invisible to the user.

4.1.4. VPN Support

Mobile platforms support virtual private networks (VPNs) that can be leveraged by developers via APIs. VPNs primarily provide confidentiality protection by encrypting user data. There are three types of VPNs: OS-level VPNs, app level-VPNs, and web-based VPNs. OS-level VPNs can be configured via management platforms and can sometimes be put into an "always-on" state. OS-level VPNs may be more power-efficient and can encrypt a large amount of user traffic. Protocols that may be used include Internet Protocol Security (IPsec) and Layer 2 Tunneling Protocol (L2TP). Unlike OS-level VPNs, app-level VPNs can be configured in multiple ways. They can leverage system VPN APIs to protect user data, or they may simply protect a single app's data. More complicated setups can deploy VPNs per mobile app, often known as a per-app VPN. Finally, web-based VPNs are easy for a user to take advantage of, often by simply agreeing to a web page's policy. Web-based VPNs use Transport Layer Security (TLS) and may not leverage the same additional protections used by other types of VPNs.

4.1.5. Authentication Mechanisms

Mobile devices offer a variety of sensors that can enable standard and biometric-based authentication. Biometric authentication on a mobile device may be used in combination with or instead of passwords or PINs. Mobile hardware typically does not contain or store raw biometric data. Instead, the biometric data is transformed (e.g., tokenized) and may be stored securely, minimizing its susceptibility to reverse engineering and potential exposure to an attacker. Biometric data is typically encrypted, stored on the device, and protected with a key available only within a dedicated security environment. Sensors leveraged for biometric authentication include:

- a fingerprint sensor for fingerprint-based authentication;
- dedicated cameras and other sensors to assist in facial recognition;
- a gyroscope, accelerometer, or pedometer for gait-based authentication; and

- a microphone for voice recognition.

Individual sensors of the same type can be of varying quality and, ultimately, more or less secure than a similar component. Some sensors are not directly exposed to developers, and access decisions are made in proprietary security environments. Although these sensors are most often used for local device authentication, they can also be used for remote authentication to enterprise resources. Another mechanism that can be used for remote authentication is a derived Personal Identity Verification (PIV) credential. This is where a mobile device leverages certificate-based authentication through a token that is associated with a PIV credential. Additional information can be found in NIST SP 800-63-3, Digital Identity Guidelines [4], and NIST SP 800-157, Guidelines for Derived Personal Identity Verification [\[40\]](#).

4.2. Enterprise Mobile Security Technologies

Technology to manage smartphones and tablets can be used to control organization-issued and personally owned devices. This technology can take many forms, such as a management tool for device configuration, an application management tool, or a mobile threat defense (MTD) tool. MTD is a category of technology that defends devices from a variety of threats posed to the devices themselves and any connected networks. Other products such as mobile identity management, mobile content management, and mobile data management also exist but are not covered in this publication. This section provides an overview of the current state and use of these technologies, focusing on their components and security capabilities. These technologies form the foundation for the recommended technical threat mitigations and countermeasures in Section 4.3.

4.2.1. Enterprise Mobility Management

EMM, which is sometimes referred to as UEM (unified endpoint management), is a solution used to deploy, configure, and actively manage mobile devices in an enterprise environment. An EMM suite may encompass mobile device management (MDM), mobile application management (MAM), MTD, and other management technologies. These management systems are developed by a variety of organizations, including mobile device manufacturers, mobile OS developers, and independent third-party development organizations. EMMs rely on the MDM APIs and protocols described in Section 4.1.3 and employ technologies to monitor mobile devices, deploy device policies, and configure device-side security technologies (e.g., secure containers).

The rest of this subsection contains a list of security capabilities that may be provided by EMMs or any of their supporting systems. Most organizations will not need all of the security capabilities listed in this subsection. Organizations that deploy mobile devices should consider the merits of each security capability, determine which services are needed for their environment, and design and acquire one or more solutions that collectively provide the necessary services for their needs. Additional guidance for implementing these technologies can be found in Section 5.

4.2.1.1. General Policy Enforcement

EMM technology can enforce enterprise security policies on a mobile device, which can configure or restrict the use of mobile functionality and security capabilities. EMM technology can automatically monitor, detect, and report when policy violations occur and automatically take action when possible and appropriate. General policy restrictions or configuration options for mobile device security include:

- Manage wireless network interfaces (e.g., WiFi, Bluetooth, NFC).
- Restrict user and app access to hardware (e.g., digital camera and removable storage) and device features (e.g., copy and paste).
- Detect changes to the approved security configuration baseline.
- Limit or prevent access to enterprise services based on the mobile device's OS version (including whether the device has been rooted/jailbroken), vendor/brand, model, or mobile device management software client version (if applicable).
- Disable debugging or developer mode.

4.2.1.2. User and Device Authentication

User and device authentication can be defined and enforced using EMM technology. Some basic options and considerations include:

- Require a password or other authenticator to unlock the device (e.g., passcode, biometric).
- Require a password/passcode and/or other authentication mechanism (e.g., token-based authentication, network-based device authentication, domain authentication, digital certificate) to access the organization's resources. This includes basic parameters for password strength, a limit on the number of retries permitted without negative consequences (e.g., locking out the account, wiping the device), and password aging.
- Have the device automatically lock itself after it is idle for a period of time (e.g., 45 seconds, 5 minutes).
- Under the direction of an administrator, remotely lock the device if it is suspected that the device is lost or was left in an unlocked state in an unsecured location.
- Wipe the device after a certain number of incorrect authentication attempts or after a predetermined time interval without it checking into the EMM. Note that the ability to recover data via an EMM after it has been wiped is limited.

4.2.1.3. Data Communication and Storage

Protections for data communications and on-device data storage can be defined and enforced using EMM technology. Considerations for these data protections include:

- Strongly encrypt data communications between the mobile device and the organization. This encryption is most often accomplished by a VPN (see Section 4.1.4), although it can be established through other uses of secure protocols and encryption.
- Strongly encrypt stored data on both built-in storage and removable media storage. Removable media also can be “bound” to particular devices so that encrypted information can only be decrypted when the removable media is attached to that specific device, thereby mitigating the risk of offline attacks on the media.
- Wipe the device before reissuing it to another user, retiring the device, etc.
- Remotely wipe the device to scrub its stored data if it is suspected that the device has been lost, stolen, or otherwise fallen into untrusted hands and is at risk of its data being recovered by an untrusted party.

4.2.2. Mobile Application Management

Some EMM systems include MAM functionality, which enables fine-grained control over different apps on a single managed device, although MAM may also be offered as a distinct third-party solution. MAM systems are designed to enable enterprise control over mobile apps that access enterprise services and/or data. These apps include privately developed apps and publicly available apps. Unlike MDMs, MAM systems do not require the device owner to enroll the device under enterprise management, nor must the owner accept installation of an enterprise profile on the device. This distinction is critical for apps designed, for example, to support business-to-business (B2B) transactions (e.g., an app provided to suppliers to enable access to an enterprise orders database). In such cases, the mobile user is not an employee of the enterprise that offers the app. For enterprises with bring your own device (BYOD) policies, the use of MAM functionality instead of MDM may help address users’ privacy concerns regarding their personal devices.

Apps used on mobile devices may be managed using EMM technology. Depending on how the device is managed and enrolled into an EMM solution, the following restrictions may be applied:

- Restrict which app stores may be used (e.g., limit access to official app stores, restrict sideloading apps).
- Restrict which apps may be installed by allowlisting allowed apps (preferable) or blocklisting prohibited apps. Allowlisting and blocklisting capabilities are highly platform-dependent and may not be available on all MAM systems.
- Restrict the permissions (e.g., camera access, location access) assigned to each app. App-wrapping technology (described further in Section 4.2.6) may be used; it is highly platform-dependent and may also limit app functionality.
- Safeguard mechanisms to install, update, and remove apps on a mobile device. Keep a current inventory of all apps installed on each device. This capability is highly platform-dependent and may not be available on all systems.
- Restrict the use of OS and app synchronization and sharing services (e.g., local device synchronization, remote synchronization services and websites).

- Distribute apps from a dedicated enterprise mobile app store provided through the EMM technology.
- Distribute the organization's apps from a dedicated mobile app store.

MAM solutions allow enterprises to control access to enterprise-specific apps and often enable an enterprise to integrate an in-house enterprise app catalog with a mobile device vendor's app store (e.g., Apple's App store, Google Play) to allow mobile users to easily install an enterprise app. Enterprise system administrators may be able to deploy apps or push out over-the-air updates to mobile users. They may also be able to restrict app functionalities without affecting the entire device, an approach that is preferred by BYOD users. Specifying and enforcing security and privacy policies is a key function of MAM systems, often including user- or role-based policies for access to specific apps and integration with remote wipe for employees who depart the organization or change roles. Encryption or containerization may be used to separate the execution environments of apps or their communication with enterprise services. Finally, MAM systems may enable enterprise system administrators to monitor app behavior, configuration compliance, or the presence of unauthorized apps on a user device.

4.2.3. Mobile Threat Defense

MTD systems are designed to detect the presence of malicious apps, network-based attacks, phishing attacks, improper configurations, and known vulnerabilities in mobile apps or the mobile OS itself. Although MTD is becoming the preferred term, the terms mobile threat protection (MTP) and endpoint protection are also colloquially used. These systems often run an agent on the device – typically a mobile app – and may initiate analysis and learning on external cloud-based platforms. MTD systems provide real-time, continuous monitoring for assessing apps after deployment to a mobile device and during runtime. MTD systems reside on the mobile device and do not rely on network connectivity. This enables detection and protection from mobile threats even if the device's network connectivity is blocked or compromised. In an enterprise context, an MTD system may be integrated with an EMM to enable user or administrator notification or automated response to remediate detected vulnerabilities or quarantine apps or devices. Some mobile platforms include built-in capabilities similar to MTD system capabilities that are not manageable by a user or administrator.

An MTD can detect and protect the mobile device, apps, and end user against attacks via the wireless network. This defense covers MitM attacks that could intercept or eavesdrop on communications or phishing attacks that could steal user credentials. MTD systems may also detect attacks against an app or OS software. For example, MTD systems may observe sideloaded apps – apps loaded from sources other than the standard mobile device vendor's app store (e.g., Apple's App store, Google Play). Sideloaded apps may be special-purpose, enterprise-loaded, or allowlisted apps specified by the enterprise. MTD systems monitor the on-the-fly behavior of mobile apps within the current mobile environment, such as when the app navigates to known malicious URLs or phishing sites. For example, MTD systems may detect communication with a blocklisted service or an app's failure to encrypt communication with an enterprise's backend service. Unexpected interactions among apps or the use of data on the user device (e.g., the app accesses a device owner's contacts or location) may also alert an MTD system to potentially malicious or risky behavior. (An EMM device agent may provide a similar

notification. An EMM system or EMM agent may take action to remediate the issue on the device.)

4.2.4. Mobile App Vetting

The goal of app vetting is to detect software or configuration flaws that may create vulnerabilities or violate enterprise security or privacy policies. An app vetting system is commonly used by enterprise system administrators before an app is deployed to a user's mobile device, unlike an MTD system, which can analyze downloaded and installed apps. App vetting can also be used to vet apps that may not be deployed by an administrator but are installed by users outside of management. Mobile apps may be developed by mobile device manufacturers (e.g., Apple's apps for iOS), the mobile OS vendor (e.g., Google apps for Android), third-party providers, or in-house enterprise developers. App developers, OS developers, and enterprise administrators may make mistakes when designing or building an app. They may also intentionally insert malicious functionality that may impact the security or privacy of the mobile user or the enterprise.

App vetting involves a sequence of activities that are typically accomplished via automated test and analysis tools, which may interact with external vetting services. App vetting systems may analyze app source code, app binaries, or general app behavior. App vetting systems can expose several security-critical issues, such as problems with the use of cryptography, the collection and handling of sensitive corporate or user data, or software dependencies on untrustworthy cloud services. Common problems with app use of cryptography include the use of weak or broken cryptographic algorithms, small key sizes, or the failure to cryptographically protect communications or stored data.

Vetting systems may also detect that an app will collect sensitive enterprise data or PII of the mobile user. Apps may be designed to use the device's camera or microphone or collect and share (or sell) sensitive information, including user location information, contact details, sensor data, photos, and messages with backend services provided by untrustworthy third parties. Mobile app vetting systems may be able to expose such issues at several phases of the app life cycle: 1) during development by communicating issues and recommended mitigations to app developers, 2) following development and prior to deployment by identifying vulnerabilities for app security analysts or enterprise system administrators, and 3) post-deployment through integration with an EMM by notifying enterprise system administrators of vulnerabilities in installed apps [\[2\]](#).

4.2.5. Virtual Mobile Infrastructure

Virtual mobile infrastructure (VMI) provides an alternative, or accompaniment, to EMM technology. Similar to virtual desktop infrastructure (VDI), which hosts a virtual desktop image for applications and data, VMI uses backend infrastructure to host a virtual mobile device and mobile apps. A user then accesses their virtual device via an app (i.e., thin client) on their phone, and the thin client provides access to a virtual OS. This approach may be viewed as "sidestepping" data confidentiality concerns by storing sensitive information in an external infrastructure versus on the mobile device itself. Since all enterprise information would only be available on the cloud-hosted infrastructure, enterprise data would likely be unavailable if there

is no network connectivity. Depending on how the VMI system is structured, VMI may or may not be deployed onto a device already provisioned into an EMM. VMI typically does not allow for device-wide controls and configurations. The deployment and use of this technology is not within the scope of this document.

4.2.6. Application Wrapping

App wrapping is a security mechanism that modifies a ready-to-run mobile executable to prevent functionality defined by a mobile administrator. This approach is often seen as an alternative to the usage of a secure container. Wrapping allows for policies to be enforced on third-party applications that the enterprise does not own. App wrapping typically requires administrative access to the mobile device, and wrapped apps are installed onto the device without being uploaded to – or vetted by – a platform’s native app store. This process of non-standard installation is also known as sideloading and could make a mobile device extremely vulnerable to attack if done incorrectly. To mitigate these potential attacks, the sideloading functionality should be disabled when not used for installing the wrapped apps. The use of app wrapping can be seen as beneficial from a usability standpoint, as users simply use apps as they normally would. From an IT administrator standpoint, deploying updates can be problematic and prone to error.

4.2.7. Secure Containers

Secure containers provide software-based data isolation designed to segment enterprise applications and information from personal apps and data. Containers may present multiple user interfaces, one of the most common being a mobile application that acts as a portal to a suite of business productivity apps, such as email, contacts, and calendar. IT administrators can manage policy sets on containers, but this process may require a software development kit (SDK) to be integrated into an app. There are multiple secure container architectures, with the two major ones colloquially referred to as *app-based* and *OS-based*.

App-based containers may not be wholly dissimilar from any other apps on a mobile device, with the exception of leveraging the management APIs provided by the OS developer. For instance, on most modern mobile platforms, any information stored within an app’s directory on a device will be encrypted by default. A more extensible implementation of an app-level container allows an enterprise to manage the cryptographic key that protects the container.

OS-based containers provide additional segmentation and data isolation when compared to app-based containers. There is often an isolated area on the platform where apps can be installed. They may also provide a FIPS 140-validated environment independent of the local cryptographic functions.

4.3. Recommended Mitigations and Countermeasures

This section identifies mitigations to the threats identified in Section 3. Table 1 depicts the threats and associates them with potential mitigations and countermeasures. Not all threats have a corresponding mitigation listed. Unaddressed threats indicate open research areas and opportunities for new technologies and products. Each listed mitigation addresses at least one threat listed in Section 3. Applying the following mitigations to the personal device of an

employee may not be easily accomplished if the user is required to configure their device without the assistance of an IT administrator. For example, it is commonplace for an EMM to create a profile that must be accepted by a user to put these mitigations in place, but an average user may be unable to acquire and properly configure the product.

Table 1. Threat Mitigations and Countermeasures

Threats	Mitigations and Countermeasures
Exploitation of underlying vulnerabilities in devices	• Security-focused device selection • OS and application isolation • Rapid adoption of software updates • Application vetting • Mobile threat defense
Device loss and theft	• EMM technologies • Mobile device security policies • Remote/ secure wipe • Notification and revocation of enterprise access for policy violations • Strong authentication
Credential theft via phishing	• User education • Mobile threat defense • Mobile device security policies • Strong authentication (e.g., multi-factor authentication) • Remote/secure wipe
Installation of malicious developer and EMM profiles	• User education • Application vetting • Mobile threat defense
Exploitation of supply chain vulnerabilities	• User education • Security-focused device selection
Accessing enterprise resources via a misconfigured device	• EMM technologies • Mobile device security policies • Notification and revocation of enterprise access for policy violations
Installation of unauthorized certificates	• Mobile threat defense
Use of untrusted mobile devices	• Security-focused device selection • EMM technologies • Mobile threat defense • Notification and revocation of enterprise access for policy violations
Wireless eavesdropping	• Use of secure connections to resources (e.g., VPN) • Mobile threat defense

Threats	Mitigations and Countermeasures
Mobile malware	• User education • Security-focused device selection • Rapid adoption of software updates • Application vetting • OS and application isolation • Mobile threat defense
Information loss due to insecure lock screen	• EMM technologies • Mobile device security policies • User education
User privacy violations	• User education • EMM technologies • Application vetting
Data loss via synchronization	• EMM technologies • Mobile device security policies • User education
Shadow IT usage	• Mobile device security policies • User education
Exploitation of vulnerabilities within the underlying EMM platform	• Cybersecurity recommended practices • User education
EMM administrator credential theft	• Additional authentication for system administrators
Insider threat	• EMM technologies • Mobile device security policies • User education

4.3.1. EMM Technologies

EMM and its supporting technologies can mitigate several of the threats defined in Section 3 and prevalent in the mobile ecosystem. EMM can assist in preventing a misconfigured device from connecting to the enterprise by securely configuring device settings prior to granting access to enterprise resources. An EMM can also actively deny a device access to enterprise data if it is in an insecure state. If an employee loses their device or it is stolen, the EMM can wipe the enterprise data on the device. EMMs can also help manage what information is shared on a device lock screen. Depending on the EMM's capabilities, the list of issues that can be mitigated may be much larger because some EMMs can be used to manage and configure other technologies like MTD and VPN applications.

Threats Addressed: Accessing enterprise resources via a misconfigured device, device loss and theft, information loss due to insecure lock screen, data loss via synchronization, insider threat, use of untrusted mobile devices

4.3.2. Cybersecurity Recommended Practices

EMM and other mobility management infrastructure rely on COTS systems to perform management functions. These core systems often run on top of general-purpose OSs and commodity hardware. It is important that computer security recommended practices – including network, physical, and personnel security – be applied to these components in the same way they are applied to general IT systems throughout industry. Protection mechanisms such as patch management [41], configuration management [42][39] (e.g., disabling serial ports on field network equipment), identity and access management, malware detection, and intrusion detection and prevention systems can be carefully planned and implemented throughout the enterprise.

Threats Addressed: Exploitation of vulnerabilities within the underlying EMM platform

4.3.3. Remote/Secure Wipe

Remote wipe enables enterprise system administrators to delete enterprise data and applications on enterprise-owned or employee-owned (BYOD) mobile devices. The remote wipe capability is widely available on mobile devices, such as smartphones and tablets, that support Android or iOS. Variations of this feature are also natively available for OSs and third-party applications that can be installed on these devices.

To enable remote wipe, a system administrator installs and configures a profile/agent on a device before enterprise data or applications are available to be used. To later perform a remote wipe, an enterprise server issues an erase command that is sent over the network to instruct the EMM device agent to delete data and/or apps on the device. The device status in the EMM console is updated after a wipe so that an administrator can confirm that the erasure has been performed.

Remote wipe may be implemented at different levels of granularity, ranging from full-device wipe (e.g., deleting everything within the system's user partition; typically, this level is used for an enterprise-owned device) to an enterprise wipe (e.g., deleting only those device settings, data, and apps previously pushed out to the user for enterprise use; typically, this level is used to delete work data that resides on an employee's personal device). Native remote wipe capabilities for iOS and Android devices require the device to be powered on (with a sufficient charge) and connected to the network. Some third-party EMM systems can execute a remote wipe even when the device is not connected to the network.

Organizations should not rely on remote wipe as the sole security control for protecting sensitive data but instead consider it to be one layer of a multi-layered approach to protection. By itself, remote wipe is a fundamentally unreliable security control. For example, an attacker could access information on a device before it is wiped, or power off a device to prevent it from receiving a remote wipe signal.

Threats Addressed: Device loss and theft, credential theft via phishing

4.3.4. Security-Focused Device Selection

Out of the box, some devices may have embedded vulnerabilities or malicious software, firmware, or hardware. Malicious actors who have access to the hardware, firmware, or software

supply chains may be able to modify device components, source code, or executables during the design or manufacturing phases. For example, an attacker could manipulate software development or integration tools (e.g., compilers, software test systems, configuration management systems), software support tools (e.g., software update or upgrade systems), system administration tools (e.g., software installation and release management systems, patch management systems), or an MDM, MAM, or EMM system. NISTIR 8151, *Dramatically Reducing Software Vulnerabilities* [29], defines a framework for and provides a broad catalog of supply chain attack patterns, which cover the malicious insertion of hardware, software, firmware, and system information.

While it is very difficult to avoid a targeted supply chain attack against a single organization or group of individuals, choosing validated devices and software and using a vetted system integrator can help mitigate the risk of broad attacks. NIST's Cryptographic Algorithm Validation Program (CAVP) "provides validation testing of [Federal Information Processing Standards] FIPS-approved and NIST-recommended cryptographic algorithms and their individual components [13]," while the NIST Cryptographic Module Validation Program (CMVP) validates cryptographic module implementations against the Security Requirements for Cryptographic Modules [17].

The National Security Agency's (NSA) National Information Assurance Partnership (NIAP) [7] is responsible for implementation of the internationally recognized Common Criteria throughout the Federal Government. Products certified through the Common Criteria program are evaluated for conformance with specific security protection profiles. NIAP's product compliance list identifies evaluated products and may be searched by vendor, technology type, protection profiles, and certifying country [8]. NSA's Commercial Solutions for Classified Program (CSfC) [9][10] also "requires specific, selectable requirements to be included in the Common Criteria evaluation" and provides a list of software or hardware systems [33], including MDM and mobile platforms, that meet these more stringent requirements. In addition, CSfC provides a Trusted Integrator List [11], which identifies companies that have met its criteria for trustworthy systems integration capabilities. Organizations are encouraged to use lists of validated products and vetted system integrators to reduce the risk of acquiring devices or software with embedded vulnerabilities. In addition to these practices, devices and software manufacturers can also follow their respective industry recommended practices for secure software development to demonstrate that they are meeting a set of requirements and have integrated them within their software development life cycle. More information about secure software development can be found in the NIST SP 800-218, *Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities* [43].

Threats Addressed: Exploitation of underlying vulnerabilities in devices, exploitation of supply chain vulnerabilities, use of untrusted mobile devices, mobile malware

4.3.5. Use Secure Connections to Resources

Encrypting data in transit to preserve confidentiality can be achieved through various implementation options. System administrators understand what data is encrypted, what algorithms are used, and how both ends are authenticating each other through their VPN. VPNs may not encrypt all data, and organizations need to take time to fully understand what

information is actually being protected. Additionally, the systems and geographic region that enterprise information is sent to are important to understand. Additional information for secure VPN implementation can be found in NIST SP 800-77 Rev. 1, *Guide to IPsec VPNs* [44], and NIST SP 800-113, *Guide to SSL VPNs* [45].

Risk from the use of untrusted networks can be reduced by using strong encryption technologies such as a VPN to protect the confidentiality and integrity of communications, as well as using mutual authentication mechanisms to verify the identities of both endpoints before transmitting data. The use of a trusted VPN requires an organization to do its due diligence regarding the security of the VPN service provider and infrastructure. Another possible mitigation is to prohibit the use of unsecured WiFi networks, such as those running known vulnerable protocols. VPNs can also assist in ensuring that all enterprise-approved applications on the device rely on TLS by default and are unable to be downgraded to HTTP. In addition, configuring DNS to leverage TLS can help protect the confidentiality of DNS requests.

Access to enterprise resources has evolved beyond the establishment of perimeters that define a safe zone and free range to access resources when you are located “within” the enterprise. Organizations should consider other technologies besides VPNs to implement zero trust architectures that provide more secure connections to resources. NIST SP 800-207, *Zero Trust Architecture*, describes the principles to take into consideration when allowing users, devices, and services access to enterprise resources [51].

Threats Addressed: Wireless eavesdropping

4.3.6. Rapid Adoption of Software Updates

Developers are constantly improving their technology not only to provide better functionality and to fix software bugs and other errors. These technological improvements and security fixes are a key reason to upgrade a device’s software and firmware. It is important that a mobile device receives these updates or else it will remain in a vulnerable state. These updates are not typically performed automatically unless a device is configured to do so. Software updates are often developed and provided for the user to manually download and install on their device. Updates should be rapidly deployed, as the longer a mobile device is vulnerable to exploits, the longer enterprise information and all other information is vulnerable to compromise.

EMMs can notify the user when OS and app updates are available. If the user does not make the appropriate updates, the administrator can enforce compliance actions. These actions include blocking or restricting access to enterprise information or the complete removal of enterprise information on the mobile device. If app management is enabled, EMMs can manually update apps and send them to mobile devices.

When patching or updating the OS or an app, enterprise administrators should consider many of the same issues that arise in standard IT environments: the urgency of the update, the likelihood that an update will “break” mission-critical functionality for users, and the ability of the user, the mobile device, and affected systems to roll back failed patches. The urgency of an update is affected by the severity of the potential impact of a vulnerability’s exploitation (e.g., critical, important, moderate, low). For example, the Common Vulnerability Scoring System (CVSS) [19] [20] is a numerical scoring system used to communicate the severity of vulnerabilities. NIST uses the CVSS to score the vulnerabilities found in the NVD. Updates to mobile apps may

interact poorly with existing enterprise infrastructure software or application software and cause a mobile app or even the entire device to become unusable.

When choosing to take corrective actions and deciding how strong such actions should be, the enterprise administrator should consider special factors that affect software deployment in the mobile computing environment. If users are traveling, offline for extended periods of time, or only connected via low-bandwidth networks (e.g., legacy cellular), updating software may be almost infeasible. To address these cases, administrators should develop mitigations in advance for unpatched mobile systems.

Best practices for mobile updates include pushing updates periodically (e.g., weekly) to acclimate users to regular patching and prevent apps from becoming excessively outdated. Administrators should identify a group of relatively tolerant users (e.g., other system administrators) and push updates to these users before patching mobile devices across the organization. By using this approach, problems with updates may be discovered and addressed before they impact a larger number of users who are less tolerant of software problems[\[41\]](#).

Threats Addressed: Exploitation of underlying vulnerabilities in devices, mobile malware

4.3.7. OS and Application Isolation

Using a secure container to isolate enterprise data is a commonplace strategy for preventing data compromise. As stated in Section 4.2.7, containers use a variety of underlying technologies to separate enterprise and user data. Secure containers often act as an EMM's device-side agent to obtain information about a device's health, enforce enterprise policy, and notify administrators of non-conformance. They can also be used to provide cryptographic confidentiality protection of data. Acting as the EMM agent, secure containers may work in conjunction with the management APIs to perform their security and management functions.

Administrators can also configure policy, receive notifications of policy violations, prevent data exfiltration, and manage device health by embedding a security-focused SDK into an app that resides on an employee device. Although this approach can be fruitful, it requires a certain level of expertise from the enterprise to develop the SDK. Another approach to isolation involves wrapping applications as mentioned in Section 4.2.6. All of these can work in concert to provide the desired degree of isolation.

Enterprises may need to employ multiple isolation mechanisms within their mobile deployment. The exact combination necessary for a particular enterprise is a function of the enterprise's unique security and operational requirements. Implementing all of the isolation mechanisms listed here may not be an appropriate response to the threats posed to an enterprise and may also be too costly to implement. Enterprises should gain an understanding of what security benefits an isolation mechanism is actually providing and what features are simply a byproduct of the underlying OS. In addition, organizations should ensure that isolation mechanisms are activated and properly configured.

Threats Addressed: Exploitation of underlying vulnerabilities in devices, mobile malware

4.3.8. Mobile Application Vetting

MAV tools can be employed to identify vulnerabilities and malicious code in mobile applications. Some mobile platforms have built-in MAV capabilities. This commits the ecosystem of mobile OS vendors to providing a layered security model. MAV tools can also integrate with many EMM and MTD systems. When an issue is discovered, an administrator can be properly informed and automatically deploy various EMM-provided remediation actions available via the EMM. These include notifying administrators, affected users, and departments; automatically removing affected apps; and disallowing access to enterprise resources. To achieve this automated operation, the EMM is integrated with MAV tools via APIs that coordinate the submission of mobile apps – one-off or in bulk – to the MAV service via the EMM dashboard. These APIs are often implemented using web services. For MAV services, EMM integration can enable a flexible conduit through which results from multiple MAV vendors can be received and aggregated at the EMM dashboard or portal without requiring all app vetting reports to conform to a single format.

Threats Addressed: Installation of malicious developer MDM profiles, mobile malware, user privacy violations, exploitation of underlying vulnerabilities in devices

4.3.9. Mobile Threat Defense

MTD, also known as, Mobile Endpoint Detection and Response (EDR), can be built into the OS or operate as a stand-alone and isolated system that detects malicious applications and other threats. The capabilities built into the OS may not be manageable by the device user or an organization. MTD systems can detect network-based attacks (e.g., MitM that could intercept and redirect or eavesdrop on communications), app-based attacks (e.g., information leakage or malicious, sideloaded apps), platform-based attacks (e.g., rootkits that undermine basic OS functions), phishing attacks (e.g., to steal credentials), and others. When coupled with an integrated EMM, these systems offer multiple remediation approaches after an attack attempt, detected data breach, or compromised device. Remediations for network-based attacks include disconnecting the device from the enterprise network, reestablishing a trustworthy connection, or blocking attempts to connect to blocklisted networks. Whenever possible, threat remediation should be accomplished on-device to rapidly mitigate the threat and eliminate dependence on network/cloud connectivity to access remediation policy actions.

For app-based attacks, an integrated EMM and MTD system can remove malicious apps or modify app permissions to limit access to sensitive enterprise resources. In cases where an integrated EMM and MTD system detects a potential attack against the mobile platform, it might notify the user to apply an OS patch or – in the extreme – remotely wipe (i.e., factory reset) the device. Integrated EMM and MTD systems are typically configured to alert the system administrator and potentially the mobile device user to the detected problem and the remediation approach initiated.

Threats Addressed: Credential theft via phishing, installation of unauthorized certificates, mobile malware, exploitation of underlying vulnerabilities in devices, installation of malicious developer and EMM profiles, wireless eavesdropping, use of untrusted mobile devices

4.3.10. User Education

Security is everyone's responsibility. The user cannot solely depend on the EMM and other third-party apps to secure their device and enterprise data. User awareness is important because the device user plays a vital role in securing the enterprise's information. Understanding the importance of securing the device and how to contribute to that security is important for both the user and the enterprise.

Providing effective ways to teach users how to protect their mobile devices is essential to understanding the importance of security mechanisms and how to apply them. This may include constant reminders of security practices via posted signage. The following are some examples of mobile device security on which device users should be trained:

- How to identify phishing attacks.
- How to properly manage authentication credentials.
- The organization's privacy policy and the personal information collected.
- How to identify malicious EMM profiles or other malicious applications.
- Why apps should only be installed from trusted sources.
- Why it is important to rapidly perform OS and application updates.

If the device users are not educated on how to properly secure their mobile devices, this oversight could endanger enterprise and user information. That's why user education is essential for enabling users to do their part in securing their mobile devices for themselves and the enterprise.

Mobile device and EMM administrators also require proper security training. Mobile security technologies often include instructional training material to ensure that mobile administrators know how to use the technology and that security controls are properly applied. The enterprise may want to identify the Workforce Categories and Specialty Areas from the National Initiative for Cybersecurity Education (NICE) Cybersecurity Workforce Framework (NIST SP 800-181) [\[46\]](#) that are of interest and applicable to the enterprise's needs. Through identifying the Workforce needs, the enterprise will be able to understand the necessary knowledge, skills, and abilities for a mobile device/EMM administrator.

Threats Addressed: Credential theft via phishing, installation of malicious developer and EMM profiles, mobile malware, exploitation of supply chain vulnerabilities, information loss due to insecure lock screen, user privacy violations, data loss via synchronization, shadow IT usage, exploitation of vulnerabilities within the underlying EMM platform, insider threat

4.3.11. Mobile Device Security Policies

The development of security policies is vital to establishing a prominent security posture through well-defined procedures and governance. The purpose of security policies is to provide a clear course of action for organizations to follow when deploying new technologies and remediating issues or other occurrences. Mobile device security policies can be established by performing a threat modeling exercise or risk assessment to understand the attack landscape and plan according to an organization's specific security needs.

Mobile device security policies can define the device configurations required for each mobile device that accesses enterprise data. For example, a configuration policy may require user authentication before accessing the mobile device or the organization's resources. Further, that policy may define the strength of the authentication mechanism or require multi-factor authentication. These types of policies can protect against an attacker gaining unauthorized access to enterprise resources.

In the case of remediation, an organization should define policies to guide the necessary actions to perform in the case of an error or attack. An organization may develop a policy that requires a mobile device to be erased/wiped if it is lost or stolen. This policy will help prevent unauthorized access to sensitive enterprise information on such a mobile device. Additionally, an organization should have procedures for reviewing and updating policies as needed, especially if there is a breach due to implementation of a weak or outdated policy.

Threats Addressed: Device loss and theft, credential theft via phishing, accessing enterprise resources via a misconfigured device, information loss due to insecure lock screen, data loss via synchronization, shadow IT usage, insider threat

4.3.12. Notification and Revocation of Enterprise Access

Every enterprise and organization should have security policies and rules that influence remediation actions when network attacks or breaches occur. These policies and rules also cover mobile devices. Remediation actions may span a spectrum of possibilities ranging from notifying affected individual users or groups of users to revoking access to enterprise data and services, wiping the data of the affected devices, or restoring them to a default pristine state (e.g., factory reset).

Notifying users of an issue is often the most basic and least aggressive remediation option. This is typically done via a push notification to the phone's notification center or potentially an SMS to follow up. Temporary revocation of access to enterprise resources is often seen as the next step if the notification does not remediate the issue. This is most easily done via the EMM agent if one is installed on the employee device. The temporary revocation may last a predefined period of time (e.g., 24 hours), and access may be automatically restored or manually restored by the enterprise's system administrators. Removing applications or wiping the mobile device are some of the more aggressive remediation options available to the enterprise. These more drastic actions can be performed because an app on their mobile system was compromised or is malicious and is the source of attacks or leaks affecting the enterprise. Note: Wiping data not owned by the enterprise can cause legal issues.

Threats Addressed: Device loss and theft, accessing enterprise resources via a misconfigured device, use of untrusted mobile devices

4.3.13. Strong Authentication

System administrators who use the EMM console have access to sensitive information about the enterprise's mobile devices. Individuals with EMM credentials can grant and revoke access to enterprise resources and collect private information about employees, such as device location. Additionally, they may be able to wipe an entire device, not just the enterprise data. For this reason, EMM administrator credentials should conform to standard password strength and

complexity rules listed in NIST SP 800-63-3 [4]. If supported by the EMM, multi-factor authentication also should be used. These additional layers of authentication for system administrators can help thwart EMM credential theft.

Threats Addressed: Credential theft via phishing, device loss and theft

5. Enterprise Mobile Device Deployment Life Cycle

There are many factors to consider when deploying mobile devices within an enterprise environment. These include selecting the correct management technologies and devices, alongside properly providing them to users. This section defines a process, as seen in **Fig. 4**, for deploying devices and managing them throughout their operational life cycle, entitled the Enterprise Mobile Device Deployment Life Cycle. Each step of the process is described below along with the necessary implementation details. Organizations may wish to document their decision-making process and implementation details in a mobile security policy.

Alternative process models and frameworks exist, and enterprises should adopt or combine the ones that suit their needs while satisfying their requirements. One example is the Mobile Computing Decision Making Framework (MCDF) – a four-stage framework that is used to determine whether a mobile solution is necessary to support an enterprise’s overall mission. More information on the MCDF can be found in the CIO Council’s Mobile Computing Decision Making Framework [12].

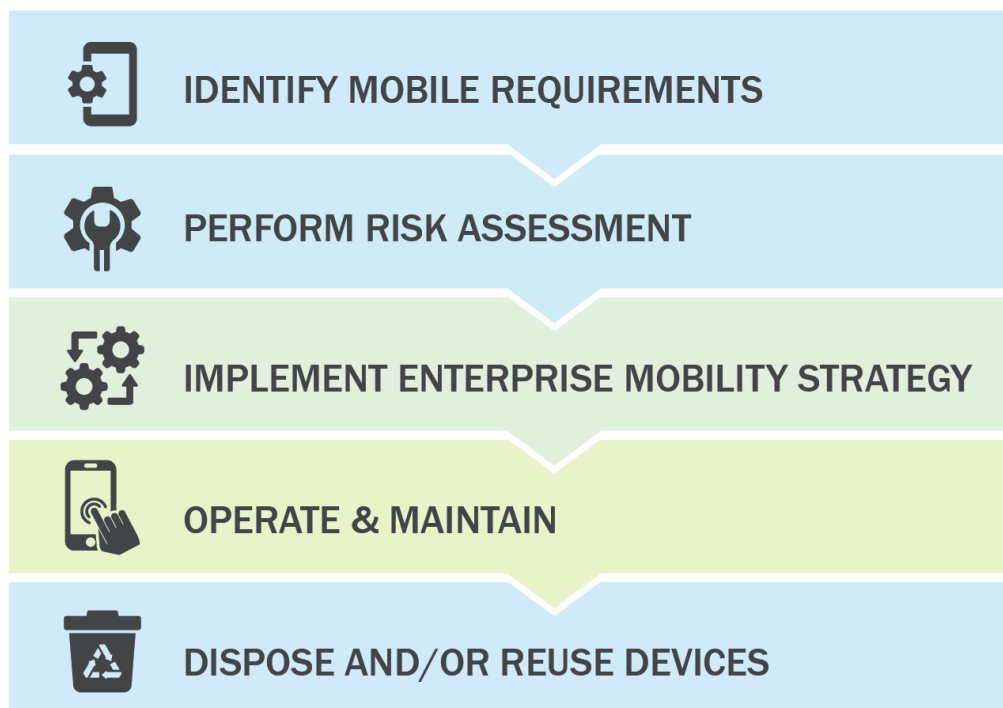


Fig. 4. Enterprise Mobile Device Deployment Life Cycle

5.1. Identify Mobile Requirements

In the first stage of this life cycle, the organization's decision makers define the mission needs and requirements for mobile devices, inventory the mobile devices already in use, and identify the mobile deployment model that fits their organization. This is all in an effort to gather requirements for managing current and future mobile devices to meet mission needs for functionality, security, and privacy. The participation of both IT-focused and business-focused decision makers is necessary at this stage to ensure that the needs of the mission will drive the technology choices in later stages.

5.1.1. Explore Mobile Use Cases

Many organizations find that mobile devices are essential to enabling their staff to meet evolving mission requirements. Tasks that might have once been accomplished in the office (at a much slower pace) are now handled "in the field," often while requiring access to enterprise data or apps and through interaction with colleagues from partner organizations. This need to meet challenging and fast-paced mission requirements should be weighed against the need to protect sensitive data and address privacy concerns, financial costs, and other issues. Developing use cases specific to an organization's needs for mobile devices can help to identify and clearly describe requirements. Common elements of use cases include understanding who users are, why they need mobile devices, and what apps or device features will be necessary for them to meet their organizational objectives.

For example, a disaster management organization may send staff members to sites affected by natural disasters – such as tornadoes, floods, and earthquakes – to provide assessments and assistance. Mobile devices are essential to reaching back to enterprise data sources and to enabling the submission of information gathered on site. Staff may also share information with members of the public; local first responders; representatives of other local, state, and federal organizations; and staff from various other non-governmental organizations (NGOs). In this use case example, the strong need for a mobile capability is clear. Backend systems may need to be restructured to enable appropriate security characteristics to support these interactions, such as ensuring the availability of transmission towers or similar in the affected site. The characteristics (e.g., durability will be important for rough worksites) and cost of the selected mobile devices should be considered carefully to ensure that all staff have the necessary equipment and that expensive devices are not too fragile for a rough worksite.

5.1.2. Survey Current Inventory

When modern mobile devices were first introduced into enterprises, management platforms were less mature and had likely not been managed in a centralized manner. These sorts of practices may have continued over time. Therefore, an inventory of the mobile systems alongside other information systems within an organization's network can be valuable when deploying a new mobile infrastructure. This can be performed by directly asking employees for the mobile devices they are using and performing network scans to understand the devices on a network. Together, these two sources of information provide a picture of the devices that are actually being used and need to be protected and/or upgraded.

Unidentified mobile devices may leave holes in the enterprise's infrastructure. These devices may not acquire the necessary security configuration, which leaves the mobile user and the enterprise unprotected from vulnerabilities and exploits. Malware or unauthorized access to the enterprise's network through the unidentified mobile device can leave the enterprise unaware of vulnerable attacks due to lack of visibility. Identifying current inventory may be performed through an inventory management methodology. NIST and DHS produced NISTIR 8011, *Automation Support for Security Control Assessments Volume 2: Hardware Asset Management* [33], which provides operational guidance for automating and assessing FISMA security controls with regard to hardware asset management.

5.1.3. Choose Deployment Model

Organizational leaders may choose from a variety of deployment models for the mobile devices to be used within their enterprise. A deployment model captures alternative options for device ownership, as well as policy and technological controls that manage device behavior. The spectrum of options ranges from devices issued by (i.e., purchased or leased by) and fully managed by the enterprise to devices owned by individuals with little or no enterprise management of device interaction with enterprise systems. The following sections describe three of the most commonly used categories of options in the spectrum. NIST SP 800-114, Rev. 1, *User's Guide to Telework and Bring Your Own Device (BYOD) Security*, identifies similar categories in the context of devices used for teleworking [34]. Additional related telework security guidance can be found in NIST SP 800-46, Rev. 2, *Guide to Enterprise Telework, Remote Access, and Bring Your Own Device (BYOD) Security* [48].

5.1.3.1. Strict Enterprise Usage

Enterprise-enabled mobile devices are issued and owned by the organization, and all users should be made aware that all information and data on those devices are controlled by the organization. Within the Federal Government, this deployment model is sometimes known as Government-furnished equipment (GFE). This section covers enterprise-enabled mobile devices that are provided to employees for enterprise use only. GFE devices strictly limit personal use; employees typically own and carry a separate personal device.

Enterprise-enabled mobile devices provide significant security benefits. Organizational leaders may consider the supply chain of candidate devices before selecting devices for purchase, and IT system administrators may develop device hardening plans before the products arrive. At deployment time, the IT staff may configure restrictive policy settings to significantly alter the functionality of the device, such as removing text messaging functionality, restricting WiFi and Bluetooth access, and ensuring that communication takes place over a VPN. In this model of enterprise-enabled device deployment, trade-offs between security and functional usability can be made entirely at the discretion of organizational leaders.

An example of a strictly enterprise-enabled deployment is a GFE that is provisioned to the end user as a fully managed or supervised device. Mobile security technologies include enrolling the device into an MDM with the use of MTD for endpoint protection and access to enterprise resources through web-based interfaces or mobile applications. An allowlist approach is implemented for mobile app deployments; all mobile apps on the device will be examined

through a mobile app vetting service before the apps are provisioned to the device or allowed to be downloaded from the managed enterprise app store [2]. Access to the official public app stores or unofficial app stores is restricted in this deployment model.

Device ownership status: Organization

5.1.3.2. Corporate-Owned Personally Enabled (COPE)

COPE devices are issued by the enterprise to employees. The COPE model is less restrictive on employee personal use. While the enterprise owns (or leases) the device and enforces usage restrictions, these restrictions are more lenient, allowing employees some personal use of the device. For example, an employee may be permitted to download certain apps or receive personal text messages on the COPE device. Although a COPE device is personally enabled, the device and the information on the device belong to the enterprise. Employees should be informed about enterprise restrictions and have appropriate expectations of software and device configurations that affect functionality and privacy.

An example of the COPE deployment model is a managed GFE device. This may include a fully supervised device or a separate enrollment to manage the device by downloading an EMM application from the official app store. MTD is used for endpoint protection and a blocklisting approach is implemented for many COPE deployments. For COPE, personal applications are allowed on the GFE device, and the end user is able to access the official public app stores, but app usage may be restricted by the enterprise blocklist. All mobile apps on the device should go through a mobile app vetting service; apps downloaded to the device are vetted during or after installation by the app vetting service and checked and maintained against an application blocklist.

Device ownership status: Organization

5.1.3.3. BYOD and Choose Your Own Device (CYOD)

The BYOD deployment model allows employees to use their personally owned mobile devices to access enterprise data and services. The employee may, for example, access both personal email and sensitive enterprise email via the same application. The BYOD model raises concerns regarding leakage of sensitive enterprise information via the device to untrustworthy third-party backend systems that communicate with various apps on the device. To protect the confidentiality and integrity of enterprise data and systems as well as the privacy of the device user/owner, IT staff may use a tool such as an EMM to enforce DLP by applying restrictions such as disabling the copy/paste feature when in enterprise applications. An enterprise should also use MTD technology to ensure that the device is protected from mobile threats and attempts to compromise the device.

A choose your own device (CYOD) device is purchased by an employee for personal use but selected from a list of devices provided by the enterprise for interacting with the enterprise's networks and software. If the employee's personal device is on the approved list and the employee installs software required by the enterprise, then the employee may use that device to access the enterprise's data and services. Employees with personal devices that are not on the approved list must often carry a second (enterprise-enabled) device for work-related activities, so choosing from the approved list allows a user to avoid carrying an additional device.

A concern with both BYOD and CYOD devices is the lack of supply-chain management. The enterprise has little to no knowledge of the device's origination or if it has been modified. A BYOD/CYOD device may be rooted or jailbroken with untrusted apps installed. The device may be infected with malware without the user's knowledge. The lack of a baseline leaves the enterprise at a disadvantage when it allows a user to access enterprise data via their device.

For the organization, CYOD offers the opportunity to limit the hardware supply chain risk and to control access to enterprise data and backend systems through enterprise protection software (e.g., an EMM or MTD agent). The advantage of CYOD over BYOD is that employees are informed in advance of the devices that are capable of running the necessary enterprise protection software and, thus, will be permitted to access enterprise resources. When IT staff members decline to allow a BYOD device because it is unable to run an enterprise EMM agent, then BYOD equals CYOD but with the appearance of IT management inconsistency and capricious application of unstated policies.

Device ownership status: Employee

5.1.4. Select Devices

The organizational mission and constraints, such as cost and deployment models, are considered in the selection of mobile devices [18]. That is why Section 5.1.1, an approach for assessing an organization's mission needs for mobile solutions is needed. Understanding the impact of mobile devices on mission needs can help an organization to focus its selection process by narrowing it to a small set of candidate devices that satisfy the organization's requirements.

Costs and security concerns related to mobile devices can impact purchasing decisions. Costs can be minimized by limiting the deployment of devices to only users who need them to support an organization's mission and by selecting devices with only the necessary capabilities (e.g., choosing a previous model rather than the "latest model"). For security, it is important to select device models that are current enough to be well supported by the manufacturer and can accommodate OS and application updates and patches.

5.1.5. Determine EMM Capabilities

Identifying the EMM capabilities required to work effectively within an enterprise is an important activity to perform before acquiring an EMM. This step requires organizational leaders to use the information gathered in the previous sections to define the capability requirements for their EMM solution. For example, the EMM must support the devices selected to meet the mission needs and, potentially, existing devices in the current inventory. Other commonly required EMM capabilities are options for integrating the EMM infrastructure into the enterprise's infrastructure. These options include "on prem" operations (i.e., running on servers hosted on-premises within the enterprise data center), support for a software as a service (SaaS) model, or product certifications/accreditations and third-party service integrations. Section 4.2 discusses many other important capabilities for EMMs and other enterprise technologies designed to support mobile computing for the enterprise. The list of required EMM capabilities will support the well-reasoned selection of an EMM for the enterprise, ensuring that it provides the necessary functional and security capabilities.

5.2. Perform Risk Assessment

Risk assessments are a foundational component of cybersecurity. The risk-assessment process can be used to identify, estimate, and prioritize risk to organizational operations and assets, staff, and other organizations that result from the operation and use of information systems. Risk assessments should be performed periodically, as the threat landscape is constantly changing and the systems to be protected are evolving. Section 5.4 addresses the topic of periodic security audits, which assess the effectiveness of controls for protecting the enterprise. Periodic risk assessments should inform security audits.

Risk assessments can be conducted at the organization, mission, or information system level. This guidance recommends that mobile devices, mobile apps, and any systems used to manage the mobile system be included as part of the risk-assessment process. The risk assessment may have mobile devices included under a larger risk assessment umbrella or be conducted against a specific mobile device deployment. A variety of risk assessment methodologies exist, such as mobile-agnostic guidance (NIST SP 800-30, Rev. 1, Guide for Conducting Risk Assessments) [14] and mobile-specific guidance (Mobile Computer Decision Framework) [12]. Another example of mobile-specific guidance also exists for performing risk assessments, such as draft NISTIR 8144, Assessing Threats to Mobile Devices & Infrastructure: The Mobile Threat Catalogue [5][6], used in conjunction with a threat modeling process, such as draft NIST SP 800-154, Guide to Data-Centric System Threat Modeling [47], and the MITRE Mobile ATT&CK Framework [15]. Organizations that fail to conduct risk assessments may inadvertently select and apply incorrect security controls or spend too many resources addressing certain risks and not enough on other risks. Enterprises are encouraged to revisit their identified requirements once a risk assessment has been performed in order to update the list of requirements based on information identified within the risk assessment.

5.3. Implement Enterprise Mobility Strategy

Resource availability, mission needs, and various other organization constraints will guide decisions on mobile deployment options, devices, and EMM systems. Some organizations must have full control of all components in the enterprise environment, so all mobile equipment must be purchased by the organization and managed by enterprise system administrators through an EMM. Other organizations allow employees to bring their own devices (possibly from an approved list) and may manage a few enterprise applications through an MAM system. By focusing on the enterprise requirements, decision makers can narrow the range of appropriate deployment options.

5.3.1. Select and Install Mobile Technology

The list of mobile technology requirements previously identified should be compared against those of the EMMs under consideration. There may not be a perfect match with a complete overlap of requirements and capabilities, especially when EMM selection must be made from a predetermined list owned by an external organization. Once an EMM selection is made, the EMM should be appropriately implemented inside the enterprise network boundary. This includes proper product configuration, which is another important step in securing enterprise mobile infrastructure. A misconfigured EMM can lead to data leaks of confidential and

proprietary enterprise information, which may include self-developed internal mobile apps, personnel data, and data that could include trade secrets.

EMM technology can be set up in different ways within the enterprise, and different architectures are possible. The two primary methods focus on the location of the EMM and associated technology. These methods are on-premises and cloud-based, sometimes referred to as the software as a service (SaaS) model. These are described below.

5.3.1.1. On-Premises Architecture

On-premises (on-prem) instances of EMM technology are less common than cloud-based ones. Organizations install and configure the EMM themselves and pay for software licenses for any underlying platforms or components. Some EMM vendors offer images and containers that can help ease the burden of installation and configuration. Organizations are encouraged to double-check the images or containers for commonplace software vulnerabilities. The primary benefit of this model is that enterprise data resides within the organization except for the allowed devices that can query and receive information that they are authorized to obtain. Enterprises can monitor this traffic alongside the authentication from the EMM to other devices. Finally, physical security of the EMM can be ensured for this model.

Below is a sample architecture that demonstrates an on-prem implementation of the mobile security technologies. MTD technologies are typically cloud-based, even if the organization's management technology is on-prem. **Fig. 5** shows the MTD as part of the cloud, although real-world deployments may significantly differ. The EMM components are hosted via on-prem servers owned and managed by the enterprise. This architecture requires considerable installation and maintenance of the technologies by the enterprise but also provides the enterprise with more control over how its data is transmitted and managed.

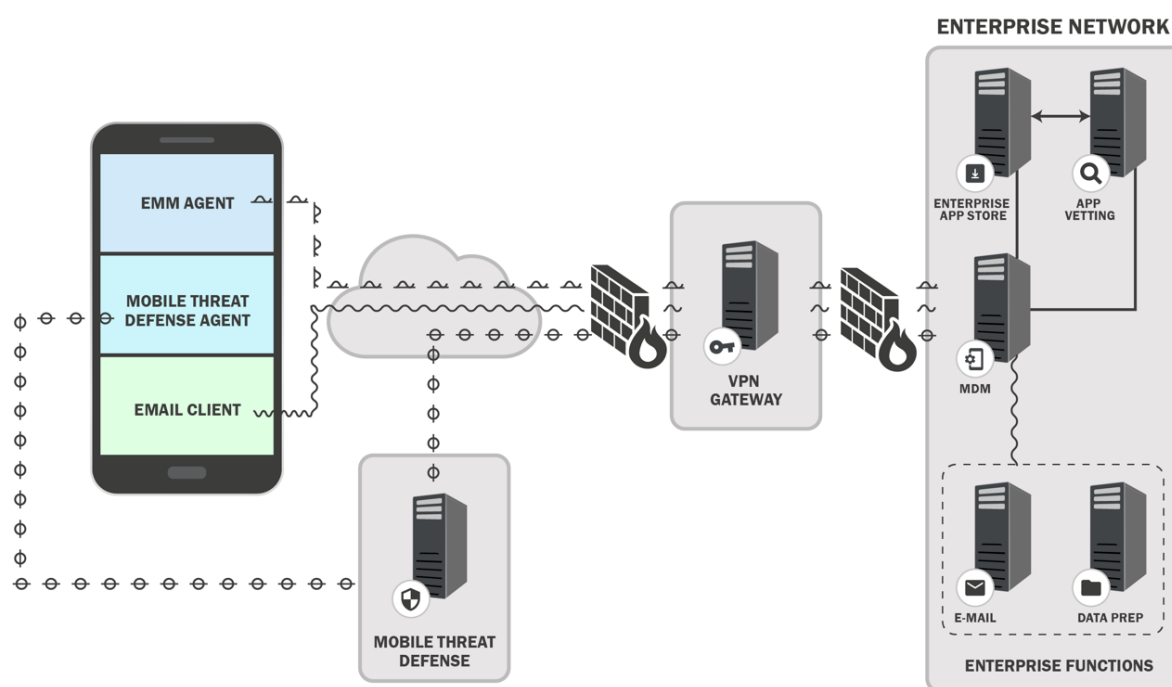


Fig. 5. Example On-Premises Mobile Architecture

5.3.1.2. Cloud Architecture

The cloud solution is an alternative to the on-prem architecture that allows mobile security technologies to be hosted external from the local enterprise network. When using the cloud solution, the mobile security technology provider gives the enterprise the ability to use its applications, which are run on a cloud infrastructure. This is also known as SaaS, and mobile security and management services are delivered via the internet to the enterprise [24].

Cloud-based EMM deployments are often easier to set up and begin using. They involve signing up for web-based services, and users are quickly taken to the primary dashboard after purchase. The most difficult aspects of setup are joining the EMM to an active directory service and proving that the email domain being used actually belongs to the company. The EMM vendor often provides unique information that must be placed into DNS and can then be externally checked. Another benefit of the SaaS model is that problems or issues can be more easily addressed by the vendor since they have access to the EMM instance and underlying platform. Finally, with this model, the enterprise data resides outside of the traditional enterprise, much like the mobile devices that the EMMs manage. This is often a key factor in organizations deciding not to use this model. Below is a sample architecture that demonstrates a cloud-based mobile enterprise architecture (e.g., MDM server, app vetting server, MTD solution).

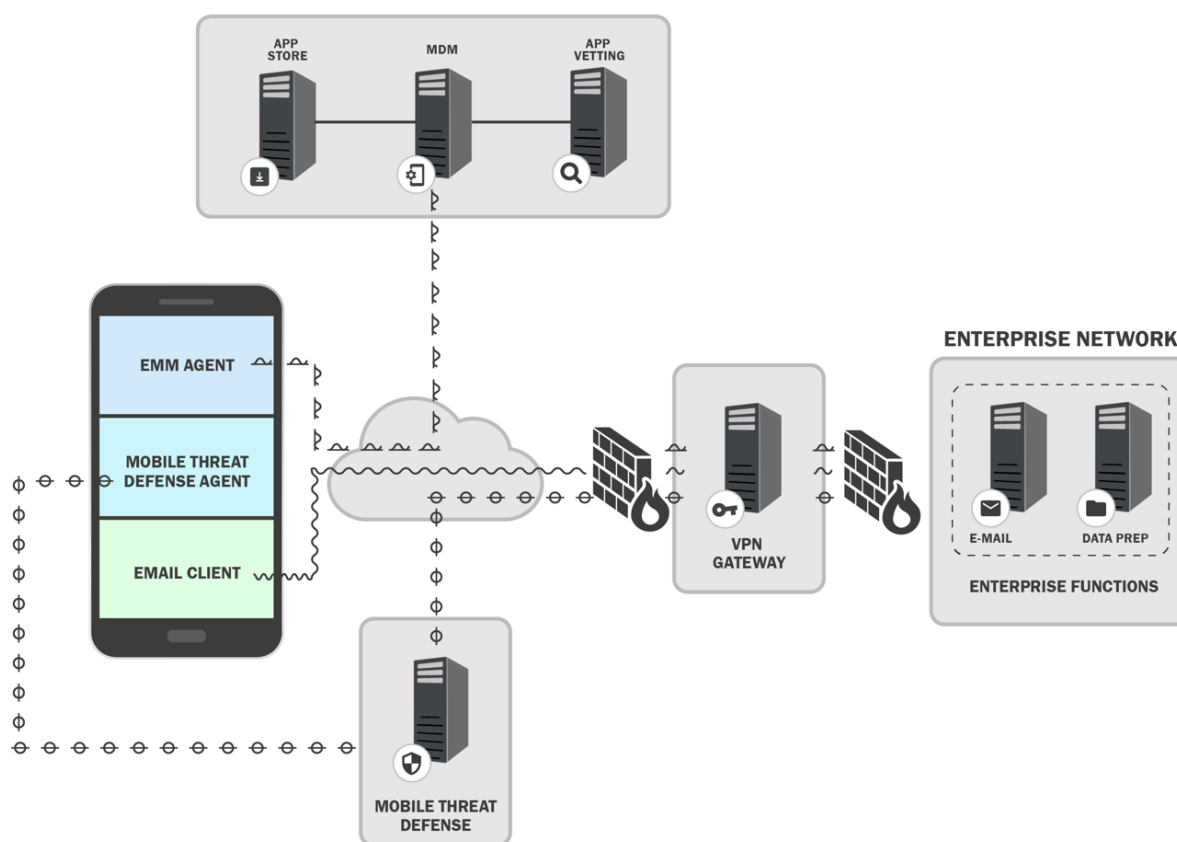


Fig. 6. Example Cloud-Based Mobile Architecture

5.3.2. Integration of EMM into the Enterprise Service Infrastructure

Both large and small enterprises may connect their EMM system to existing enterprise infrastructure services to improve the security management of mobile devices. Such services support authentication, identification, and access control to enterprise networks and resources. The Remote Authentication Dial-In User Service (RADIUS) is a standard network authentication service protocol that provides authentication of access credentials followed by policy-based network resource assignments (e.g., Internet Protocol [IP] address, permitted network connection time). Directory services, such as Microsoft's Active Directory, map network resources (e.g., volumes, printers, users, devices) to network addresses. Enterprise systems use the Lightweight Directory Access Protocol (LDAP) to communicate with directory services. Another set of services enables remote connectivity via a VPN to enterprise systems.

By integrating an EMM with enterprise backend infrastructure services such as RADIUS or directory services, an organization can enable finer-grained management of mobile device access to mission-critical enterprise resources. System administrators can set policy-based configurations for mobile devices to constrain access to sensitive resources, depending on mobile device conditions (e.g., connection from a public WiFi network or user-managed device running a corporate application). When enterprises deploy an EMM without integrating it with their backend security infrastructure, mobile device connections to the enterprise network may be

managed via global passphrases for connection to the enterprise WiFi network. Mobile devices with WiFi network access can then reach any of the services on the enterprise network, meaning that when a device is connected to the WiFi network, it can access everything on the typical enterprise network.

5.3.3. Set Policy, Device Configuration, and Provision

In certain deployment models, mobile devices should be properly set up before they can be provided to enterprise users. IT-focused and business-focused decision makers should work together to define an acceptable mobile device usage policy for these devices. The usage policy should address the standard security protections to be applied to all enterprise mobile devices and specify the permissions and special configurations that apply to users with different organizational roles. Devices can then be properly configured and provisioned to enforce the chosen policy. For organizations with a less stringent stance on device usage, such as BYOD, users should be made aware of the mobile device usage policy and signal their acknowledgement of the policy.

5.3.4. Define EMM Policy

An EMM policy is a set of rules that defines what a user is allowed (or not allowed) to do on their mobile device and the mobile device configuration requirements. EMM policies are put in place to assist in securing enterprise data within the mobile device. To do so, the enterprise must understand the types of data that the user handles (e.g., sensitive data), the risk factors, and the proper way to protect that data from accidental or intentional threats. Upon understanding these key factors, the enterprise then documents the EMM policy and applies the policy configurations within the EMM.

These policies may vary per user or device since a particular user group or role within the enterprise may have different permissions to adequately perform their duties. If the EMM policy is not well defined, the user permissions may not accurately reflect the policy requirements, and a user may be given too much or too little access to enterprise data. This could negatively impact an employee's ability to accomplish their work or allow the employee unauthorized access to enterprise information. Some examples of elements to include in an EMM policy are password requirements, device encryption, VPN requirements, and geofencing.

5.3.4.1. Consider Personal Account Usage

One of the primary means of communication within an enterprise is email. While most businesses provide work email accounts to their employees, others might allow an employee to use a personal email account to handle business communication. Email may be used for general communication between employees, account establishment, password initiation/reset, the sharing of sensitive information, and enterprise alerts/notifications.

Using personal email accounts leaves the enterprise without security control over the personal email accounts and the enterprise information that may be stored therein. Similar issues also arise with other cloud-based services (e.g., cloud-based storage and sharing of documents). Without this control, sensitive enterprise information could be transferred to unauthorized

recipients, the enterprise cannot control or have knowledge of what servers its emails are transmitted through, and it cannot apply enterprise-level security protection for its emails. Another concern is litigation against the enterprise; the inability to back up or archive personal email accounts could make it difficult for an enterprise to respond to a demand for discovery or a Freedom of Information Act (FOIA) request. If an employee resigns or is terminated, the enterprise is unable to remove that person's access to enterprise emails that were sent to their personal email address. This security gap could allow a former employee to retain access to sensitive enterprise data.

Enterprise email is the prime option for establishing account access for individuals because – as mentioned above – enterprise email addresses give an enterprise optimum control over its data. Access-control policies and privileges can be provisioned to a specified enterprise email account that coincide with the employee who uses the email address. Personal email addresses can be used in a similar fashion, but enterprises are left with less control of information sent to them. Finally, shared—emails accounts – enterprise or personal – make it difficult to manage access. Each employee on the shared account is given the same access privileges and repudiate responsibility unless there is another way of monitoring individual access.

5.3.4.2. Device Configuration

Device configuration is the system configuration of a mobile device before it is provisioned to the user. The system configuration may include updating the OS to the most recent release and establishing password length requirements. How devices are configured depends on the device deployment model used by the enterprise.

The device configuration process for enterprise-issued and BYOD devices is different because of how devices are ultimately provided to users. Enterprise-issued devices can be preconfigured in-house, or the enterprise can have a mobile device vendor preconfigure the devices prior to shipping them to the users, such as Apple's Automated Device Enrollment and Android's Zero Touch enrollment. In the case of BYOD devices, an enterprise can request that each device owner bring their device into the enterprise to be properly configured for enterprise access.

The requirements for device configuration may vary per enterprise. An enterprise may reference suggested secure mobile device configuration guidance from established entities. The Defense Information Systems Agency (DISA) provides Security Technical Implementation Guides (STIGs) that dictate detailed configuration standards for the Department of Defense (DOD). The Center for Internet Security (CIS) offers the CIS benchmarks, which are "best-practice security configuration guides both developed and accepted by government, business, industry and academia" [\[35\]](#)[\[36\]](#). NIST hosts the National Checklist Program (NCP) [\[39\]](#), which supplies checklists for securely configuring specific types of technology. Device manufacturers may also provide suggested configurations for their mobile products.

5.3.4.3. Device Provisioning

Device provisioning is often implemented by enrolling a device into the EMM by installing an EMM certificate onto each device that provides in-depth security features and privileged device access to the enterprise. Provisioning a mobile device requires a device to have the necessary certificate to be enrolled in an EMM service. This certificate is installed on a device and allows

the EMM to verify that the device can be provisioned. Once the device is provisioned to the EMM, the appropriate EMM policies are applied to the mobile device, and if the device configuration is not automatically updated, the device will need to be configured to meet the policy requirements. After the provisioning process is complete, the device user has access to enterprise data (e.g., email, calendar, contacts), and the enterprise is able to monitor the device and ensure that it is compliant with their enterprise policies.

Devices may be provisioned in-person or remotely. In-person provisioning requires an administrator to physically have the device to install the EMM certificate and confirm that the device is properly provisioned. Remote provisioning requires the device user to implement the provisioning process on their own. The user may not provision the device properly, which may render the device and enterprise data vulnerable.

5.3.5. Verification Testing

To protect the operational enterprise environment, as well as enterprise and user data, it is important to verify the device configurations and software installed on mobile devices that connect with the enterprise. Before deploying an app, software update, or patch throughout the enterprise, enterprise administrators may run pre-deployment tests to provide insight into how the change may impact the security or functionality of existing enterprise systems. For significant software deployments or major updates, administrators may want to first deploy to a limited group of users to assess the impacts to the production environment.

Allowing mobile devices to access enterprise resources can better enable staff members to execute the enterprise mission. However, mobile devices also carry security risks for enterprise systems, data, and users. Verifying that mobile devices and their applications have acceptable configurations is essential to ensuring that the benefits of mobile access outweigh the security risks that they present to the enterprise ecosystem.

Mobile device or app-level configurations can significantly impact the security posture of the enterprise. Thus, permissions for the device or individual apps may be granted depending on specific configuration settings. Network configurations may include an obligation to authenticate and use a VPN before permitting connection to an enterprise wireless network. A geofencing policy may specify that a device operating within a particular geographic region be granted different permissions than the same device used within a different region. Different users, devices, or apps may be granted different permissions for accessing enterprise backend services (e.g., a database holding sensitive information), depending on the app or device configurations. In many cases, mobile device security features are configured to better protect the enterprise in addition to the mobile device itself: device data encryption, screen lock timeout, password, and application firewall requirements are configurable and contribute to the security posture of the enterprise. Finally, enterprise policy may restrict the apps that may be installed on the device, require updates to apps or the mobile OS, or limit access to some of the device features in order to protect enterprise systems or data.

5.3.6. Deployment Testing

Enterprise networks and applications require software updates to improve functionality, patch vulnerabilities, fix bugs, or enable new hardware deployment. To make sound enterprise

deployment decisions, systems and network administrators may first perform deployment testing before pushing new software into the production environment.

Administrators consider a broad spectrum of test scenarios to evaluate a software update and decide what tests will be sufficient to indicate that the update is ready for the production environment. A phased approach to component level, feature, network, and enterprise-wide testing is typically recommended for deployment testing.

For example, when introducing a new enterprise capability, such as managed mobile devices or mobile application vetting, the administrator should consider rolling out a limited trial with only a small set of carefully chosen users. After the trial deployment has been operating satisfactorily for a predetermined period of time, and if the user experience and satisfaction have met their target level, the organization may then be ready for an enterprise-wide deployment. Following this approach not only ensures minimal disruption to the enterprise operation and a satisfactory user experience but also facilitates the discovery of security issues as early as possible in the deployment process.

5.4. Operate and Maintain

It is necessary to design and implement security controls to protect enterprise systems, as well as enterprise and user data. However, the initial deployment of controls is not sufficient to protect an operational enterprise. In addition, IT audits should be used to periodically evaluate the effectiveness of security controls for protecting the evolving enterprise, identify security issues, and modify or add controls to better protect the system in the future. Auditors need data to perform those evaluations, and mobile device usage logs provide important data for assessing the effectiveness of controls on the mobile computing environment.

5.4.1. Auditing

In order to keep up with a rapidly changing attack surface and cybersecurity landscape, the enterprise security team may practice and conduct security assessments. An essential component of such assessments is the periodic audit of the enterprise IT and mobile networking infrastructure. A comprehensive audit should cover the following:

- Enumerate the enterprise audit objectives;
- Establish a security baseline through periodic (e.g., annual) audits;
- Rely on auditors with well-established (and verified) security assessment experience;
- Develop an automated audit process to cover all of the enterprise IT infrastructure, including mobile devices;
- Analyze the data generated by the audit process rather than relying on compliance checklists;
- Use a third-party auditor to report risks facing the enterprise.

Periodic audits should include the enterprise mobile infrastructure and device management systems, as well as components such as EMM/MDM, services for mobile app vetting, integration with backend services, and the employees' mobile devices and their applications. The audit

should help the enterprise security team assess whether the benefits of mobile access outweigh the security risks that they present to the enterprise ecosystem.

5.4.2. Device Usage

An organization should develop security and privacy policies for mobile device (and app) usage. A key element of that policy is enterprise monitoring of device/app usage. EMM, MAM, and many mobile network monitoring systems enable enterprise administrators to track or monitor mobile user activities, including the following:

- identification of all device apps,
- app usage patterns (e.g., downloads, when/how often an app is launched),
- device features used by each app (e.g., microphone, camera),
- data used by an app (e.g., user location, contacts),
- device/user geographical location, and
- phone calls (e.g., phone number, name, time duration, date, location).

An appropriate monitoring policy for devices/apps should consider many factors, including the organization's mission (and how the mobile device/app supports that mission), security and privacy characteristics of the enterprise data and systems accessed via the device, the user's relationship to the enterprise (e.g., employee, contractor, employee of a partner organization, members of the general public), deployment model (e.g., -enterprise-owned, BYOD), and user privacy. A monitoring policy that is appropriate for enterprise-owned devices carried by employees in a highly sensitivity environment might include tracking the location of the device/user and geofencing the use of certain applications. Such a policy would be unacceptable (and likely infeasible to implement) for individually owned devices of employees of a partner organization who are visiting the enterprise site.

User privacy is an important consideration because most devices will contain some personal user information, and certain types of monitoring (e.g., geolocation) may bring enterprise interests into conflict with privacy regulations. Organizations that do business within the European Union (EU) should also consider how the EU's privacy and data protection regulation (i.e., the General Data Protection Regulation [30]) constrains mobile device/app usage monitoring.

5.5. Dispose of and/or Reuse Device

Mobile devices may hold sensitive information, such as passwords, account numbers, emails, voicemails, text message logs, or mission-specific data (e.g., sensitive law enforcement information). When a mobile device must be disposed of, it is important to take the proper steps to ensure that sensitive information does not fall into the wrong hands.

While techniques such as degaussing, memory overwriting, or even physical grinding can be used to sanitize magnetic media, these techniques are not effective for sanitizing the solid-state memory used in mobile devices. However, most mobile devices now store user data on self-encrypting drives (SEDs), which provide "always-on" encryption. Mobile OSs leverage the encryption inherent in the SED to provide "hard reset" or "factory reset" functionality to clear

nearly all information from the device's memory using a "cryptographic erase" technique [16]. Cryptographic erase is accomplished by sanitizing the encryption key for the drive, rendering the encrypted user data unreadable. It is essential to activate whole-device encryption before a device is deployed and to perform a factory reset operation to cryptographically erase all user data before disposing of a device.

There are two additional considerations for secure device disposal: assured destruction of the drive encryption key and the destruction of user data on removable memory cards (e.g., SIM or Secure Digital [SD] cards). If the device encryption key is backed up or escrowed outside of the device, it is possible that the key could be used to recover user data on the device. The organization should address the existence and location of such backups when designing device sanitization procedures.

In addition to storing information such as photos and downloaded documents on the device's internal memory, many mobile devices store such information on an external SD card. Contacts, voicemails, and text message logs may be stored on a SIM card as well as in the device's internal memory. A factory reset will not clear the information contained on SIM or SD cards used with the device. To remove all information from these cards, they should be physically removed and destroyed. A thorough device disposal process includes both a factory reset and the removal of any associated cards.

References

- [1] Joint Task Force (2020) Security and Privacy Controls for Information Systems and Organizations. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-53, Rev. 5. Includes updates as of December 10, 2020. <https://doi.org/10.6028/NIST.SP.800-53r5>
- [2] Ogata MA, Franklin JM, Voas JM, Sritapan V, Quirolgico S (2019) Vetting the Security of Mobile Applications. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-163, Rev. 1. <https://doi.org/10.6028/NIST.SP.800-163r1>
- [3] Cichonski JA, Franklin JM, Bartock MJ (2016) Guide to LTE Security. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-187. <https://doi.org/10.6028/NIST.SP.800-187>
- [4] Grassi PA, Garcia ME, Fenton JL (2017) Digital Identity Guidelines. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-63-3, Includes updates as of March 02, 2020. <https://doi.org/10.6028/NIST.SP.800-63-3>
- [5] National Institute of Standards and Technology (2023), Mobile Threat Catalogue, Available at <https://pages.nist.gov/mobile-threat-catalogue/>
- [6] Franklin JM, Brown CJ, Dog SE, McNab N, Voss-Northrop S, Peck M, Stidham B (2016) Assessing Threats to Mobile Devices & Infrastructure: The Mobile Threat Catalogue. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Interagency or Internal Report (IR) 8144. Available at <https://csrc.nist.gov/publications/detail/nistir/8144/draft>
- [7] National Information Assurance Partnership (NIAP) (2023) *National Information Assurance Partnership*. Available at <https://www.niap-ccevs.org/>

- [8] National Information Assurance Partnership (NIAP) (2023) *Product Compliant List*. Available at <https://www.niap-ccevs.org/Product/>
- [9] National Security Agency (NSA) (2023) *Commercial Solutions for Classified Program (CSfC)*. Available at <https://www.nsa.gov/Resources/Commercial-Solutions-for-Classified-Program/>
- [10] National Security Agency (NSA) (2023) *Commercial Solutions for Classified Program (CSfC) Components List*. Available at <https://www.nsa.gov/Resources/Commercial-Solutions-for-Classified-Program/Components-List/>
- [11] National Security Agency (NSA) (2023) *Commercial Solutions for Classified Program (CSfC) Trusted Integrator List*. Available at <https://www.nsa.gov/Resources/Commercial-Solutions-for-Classified-Program/Trusted-Integrator-List/>
- [12] Federal CIO Council, Mobile Computing Decision Framework, May 23, 2013.
- [13] National Institute of Standards and Technology (2023) *Cryptographic Algorithm Validation Program (CAVP)*. Available at <https://csrc.nist.gov/projects/cryptographic-module-validation-program>
- [14] Joint Task Force Transformation Initiative (2012) Guide for Conducting Risk Assessments. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-30, Rev. 1. <https://doi.org/10.6028/NIST.SP.800-30r1>
- [15] The MITRE Corporation (2023) *Adversarial Tactics, Techniques & Common Knowledge Mobile Profile (ATT&CK)*. Available at <https://attack.mitre.org/tactics/mobile/>
- [16] Kissel RL, Regenscheid AR, Scholl MA, Stine KM (2014) Guidelines for Media Sanitization. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-88, Rev. 1. <https://doi.org/10.6028/NIST.SP.800-88r1>
- [17] National Institute of Standards and Technology (2023) *Cryptographic Module Validation Program (CMVP)*. Available at <https://csrc.nist.gov/projects/cryptographic-module-validation-program>
- [18] Miller JF (2013) *Supply Chain Attack Framework and Attack Patterns*, MITRE Technical Report MTR140021. Available at <https://www.mitre.org/sites/default/files/publications/supply-chain-attack-framework-14-0228.pdf>
- [19] First.Org, Inc. (2023) *Common Vulnerability Scoring System SIG*. Available at <https://www.first.org/cvss/>
- [20] National Institute of Standards and Technology (2023) *National Vulnerability Database: Vulnerability Metrics*. Available at <https://nvd.nist.gov/vuln-metrics/cvss>
- [21] Apple (2023) *Apple Platform Security Guide*. Available at https://help.apple.com/pdf/security/en_US/apple-platform-security-guide.pdf
- [22] Android (2023) *Android Enterprise Security Paper*. Available at https://source.android.com/security/reports/Google_Android_Enterprise_Security_Whitepaper_2020.pdf
- [23] Department of Homeland Security (2023) *Study on Mobile Device Security*. (Washington, DC). Available at <https://www.dhs.gov/publication/st-mobile-device-security-study>
- [24] Franklin JM, Bowler K, Brown CJ, Dog SE, Edwards S, McNab N, Steele M (2019) *Mobile Device Security: Cloud and Hybrid Builds*. (National Institute of Standards and

- Technology, Gaithersburg, MD), NIST Special Publication (SP) 1800-4.
<https://doi.org/10.6028/NIST.SP.1800-4>
- [25] Lookout (2023) *What You Need To Know About The New Android Vulnerability, "Stagefright"*. Available at <https://www.lookout.com/blog/stagefright>
 - [26] Armis (2023) The Attack Vector "BlueBorne" Exposes Almost Every Connected Device. Available at <https://www.armis.com/blueborne/>
 - [27] Google (2023) *The Android Management API*. Available at <https://developers.google.com/android/management/introduction>
 - [28] Apple (2023) *Mobile Device Management Protocol Reference*. Available at <https://developer.apple.com/library/content/documentation/Miscellaneous/Reference/MobileDeviceManagementProtocolRef/1-Introduction/Introduction.html>
 - [29] Black PE, Badger ML, Guttman B, Fong EN (2016) Dramatically Reducing Software Vulnerabilities: Report to the White House Office of Science and Technology Policy. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Interagency or Internal Report (IR) 8151. <https://doi.org/10.6028/NIST.IR.8151>
 - [30] Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation). Available at <http://data.europa.eu/eli/reg/2016/679/oj>
 - [31] Health Insurance Portability and Accountability Act of 1996, H. Rept. 104-736, H.R. 3103. Available at <https://www.govinfo.gov/app/details/CRPT-104hrpt736/CRPT-104hrpt736>
 - [32] McConnell S (2004) *Code Complete: A Practical Handbook of Software Construction* (Microsoft Press, Redmond, WA), 2nd Ed.
 - [33] Dempsey KL, Eavy P, Moore G (2017) Automation Support for Security Control Assessments: Volume 2: Hardware Asset Management. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Interagency or Internal Report (IR) 8011, Vol. 2. <https://doi.org/10.6028/NIST.IR.8011-2>
 - [34] Souppaya MP, Scarfone KA (2016) User's Guide to Telework and Bring Your Own Device (BYOD) Security. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-114, Rev. 1. <https://doi.org/10.6028/NIST.SP.800-114r1>
 - [35] Center for Internet Security (2023) *Apple iOS Benchmark*. Available at https://www.cisecurity.org/benchmark/apple_ios/
 - [36] Center for Internet Security (2023) *Google Android Benchmark*. Available at https://www.cisecurity.org/benchmark/google_android/
 - [37] Department of Justice (2022) *The Privacy Act of 1974*. Available at <https://www.justice.gov/opcl/privacy-act-1974>
 - [38] National Institute of Standards and Technology (2023) *National Vulnerability Database*. Available at <https://nvd.nist.gov/>
 - [39] National Institute of Standards and Technology (2023) *National Checklist Program Repository*. Available at <https://nvd.nist.gov/ncp/repository>
 - [40] Ferraiolo H, Cooper DA, Francomacaro S, Regenscheid AR, Burr WE, Mohler J, Gupta S (2014) Guidelines for Derived Personal Identity Verification (PIV) Credentials. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-157. <https://doi.org/10.6028/NIST.SP.800-157>

- [41] Souppaya MP, Scarfone KA (2022) Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-40, Rev. 4. <https://doi.org/10.6028/NIST.SP.800-40r4>
- [42] Scarfone KA, Jansen W, Tracy MC (2008) Guide to General Server Security. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-123. <https://doi.org/10.6028/NIST.SP.800-123>
- [43] Souppaya MP, Scarfone KA, Dodson DF (2022) Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-218. <https://doi.org/10.6028/NIST.SP.800-218>
- [44] Barker EB, Dang QH, Frankel SE, Scarfone KA, Wouters P (2020) Guide to IPsec VPNs. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-77, Rev. 1. <https://doi.org/10.6028/NIST.SP.800-77r1>
- [45] Frankel SE, Hoffman P, Orebaugh AD, Park R (2008) Guide to SSL VPNs. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-113. <https://doi.org/10.6028/NIST.SP.800-113>
- [46] Petersen R, Santos D, Wetzel KA, Smith MC, Witte GA (2017) Workforce Framework for Cybersecurity (NICE Framework). (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-181, Rev. 1. <https://doi.org/10.6028/NIST.SP.800-181r1>
- [47] Souppaya MP, Scarfone KA (2016) Draft NIST SP 800-154, Guide to Data-Centric System Threat Modeling. (National Institute of Standards and Technology, Gaithersburg, MD), Draft NIST Special Publication (SP) 800-154. Available at http://csrc.nist.gov/publications/drafts/800-154/sp800_154_draft.pdf
- [48] Souppaya MP, Scarfone KA (2016) Guide to Enterprise Telework, Remote Access, and Bring Your Own Device (BYOD) Security. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-46, Rev. 2. <https://doi.org/10.6028/NIST.SP.800-46r2>
- [49] Franklin J, Howell G, Boeckl K, Lefkovitz N, Nadeau E, Shariati B, Ajmo J, Brown C, Dog S, Javar F, Peck M, Sandlin K (2020) Mobile Device Security: Corporate-Owned Personally-Enabled (COPE) (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 1800-21. <https://doi.org/10.6028/NIST.SP.1800-21>
- [50] Boeckl K, Grayson N, Howell G, Lefkovitz N, Ajmo J, McGinnis M, Sandlin K, Slivina O, Snyder J, Ward P (2022) Mobile Device Security: Bring Your Own Device (BYOD) (National Institute of Standards and Technology, Gaithersburg, MD), Second Draft NIST Special Publication (SP) 1800-22. Available at <https://www.nccoe.nist.gov/sites/default/files/2022-11/mdse-nist-sp1800-22-draft-2.pdf>
- [51] Rose SW, Borchert O, Mitchell S, Connelly S (2020) Zero Trust Architecture. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-207. <https://doi.org/10.6028/NIST.SP.800-207>

Appendix A. Change Log

In May 2023, the following changes were made to the report (in Revision 2):

- Reorganized the content and made editorial changes throughout the report to improve clarity and usability.
- Reformatted all content to follow the latest NIST technical report template.
- Updated Executive Summary to cover updates in the revision.
- Section 1.1 – Separated the Purpose and Scope section to go into more detail about each.
- Section 1.5 – Included a section on Document Conventions used in this revision.
- Section 2 (original) – Focused on Mobile Device Characteristics, and removed Threats and Vulnerabilities from Section 2 and gave it its own section, Section 3.
- Section 3 – Updated the list of threats to mobile devices.
- Section 3.2 – Added a list of threats to mobile management systems.
- Section 4 – Expanded the section on Mobile Security technologies to include the latest available technology.
- Section 4.3 – Added Section 4.3, which provides a list of mitigations and countermeasures to address the threats described in Section 3.
- Section 5 – Updated the Enterprise Mobile Device Deployment Lifecycle.
- Appendix A (original) - Removed Appendix A and referenced related security control mappings in the introduction of Section 3.
- Appendix B (original) – Removed Appendix B, Acronyms and Abbreviations.